LATTICE

La cybersicurezza sovrana dell'Italia post-quantum

Architettura, crittografia ML-DSA-65
e infrastruttura on-premise
nell'era della minaccia quantistica

PRIMA EDIZIONE · 2026

© 2026 — Lattice Network. Tutti i diritti riservati.

Quest'opera è pubblicata in self-publishing su Amazon KDP. È vietata la riproduzione, anche parziale, con qualsiasi mezzo, senza autorizzazione scritta dell'editore.

I marchi citati (ML-DSA, ML-KEM, NIST, FIPS, Signal, WhatsApp, Microsoft, Google, AWS, Bitcoin, OpenTimestamps, ecc.) appartengono ai rispettivi proprietari e sono usati a scopo esclusivamente descrittivo e formativo.

Le citazioni di casi reali nei capitoli 5, 10, 11 e 13 sono basate su situazioni effettive ma anonimizzate. Nomi, date e dettagli identificativi sono stati modificati per ragioni di riservatezza commerciale e di sicurezza informatica.

ISBN: assegnato in fase di pubblicazione KDP.
Prima edizione: 2026 · Lingua: italiano · Formato: paperback 15.24 × 22.86 cm.

INDICE

PREFAZIONE

EXECUTIVE SUMMARY · Per CEO, CISO, Legal

PARTE I — IL PROBLEMA REALE

Capitolo 1 — Le comunicazioni aziendali sono fuori controllo

Capitolo 2 — Perché l'Italia è esposta più di chiunque altro

Capitolo 3 — Anatomia di un attacco "Harvest Now, Decrypt Later"

PARTE II — LA SOVRANITÀ

Capitolo 4 — Cosa significa davvero "sovrano" nel software

Capitolo 5 — Cloud pubblico, SaaS estero e il mito del "private link"

Capitolo 6 — Self-hosting e on-premise come scelta strategica

PARTE III — LATTICE NETWORK

Capitolo 7 — L'architettura di Lattice Network

Capitolo 7B — Block Explorer pubblico e Gateway Delegation

Capitolo 8 — ML-DSA-65 e ML-KEM-768: i nuovi standard NIST

Capitolo 9 — QBFT, Loopix, Zero-Knowledge

Capitolo 10 — Certify: la PEC sovrana

Capitolo 11 — Pulse: la chat sovrana stile Signal

PARTE IV — COMPLIANCE E CASI

Capitolo 12 — NIS2, DORA, GDPR: la mappa di conformità

Capitolo 13 — Casi d'uso reali

Capitolo 14 — Roadmap dell'autosovranità

APPENDICI

A. Glossario tecnico

B. Come verificare indipendentemente una ricevuta Certify

C. Specifica del formato della ricevuta PEC court-grade

D. Bibliografia

E. Il Manifesto Lattice (12 principi)

PREFAZIONE

Ogni epoca tecnologica ha un suo momento di soglia. Quello che separa il "prima" dal "dopo", il "credevamo" dal "ora sappiamo". Per la crittografia, quel momento ha un nome e — verosimilmente — anche una data approssimativa: si chiama Q-Day, ed è atteso tra il 2030 e il 2034.

Quando ho letto per la prima volta la bozza di questo libro, ho avuto due reazioni in rapida successione. La prima è stata di sollievo: finalmente qualcuno racconta in italiano, e per un pubblico di decisori, ciò che a Brussels, a Bonn e a Washington si dice da almeno cinque anni. La seconda è stata di inquietudine: perché in Italia, nel 2026, dobbiamo ancora spiegare a un consiglio di amministrazione bancario che la crittografia che protegge gli archivi della sua clientela ha una data di scadenza.

Eppure è così. Il National Institute of Standards and Technology degli Stati Uniti — l'ente che da sessant'anni stabilisce gli standard crittografici che proteggono il mondo intero — ha pubblicato nel 2024 i primi tre standard di crittografia *post-quantistica*: FIPS 203, FIPS 204 e FIPS 205. Sono algoritmi liberi, open source, già implementati in librerie di riferimento (PQClean, libsodium, BoringSSL). La Germania, attraverso il BSI, ha emesso linee guida vincolanti per la pubblica amministrazione federale. La Francia, attraverso l'ANSSI, ha attivato una task force di transizione. La National Security Agency americana ha pubblicato la CNSA 2.0, che impone l'uso di crittografia post-quantistica per tutte le comunicazioni classificate entro il 2030.

E l'Italia? L'Agenzia per la Cybersicurezza Nazionale (ACN), nata nel 2021, ha pubblicato un documento di posizionamento generico nel 2023. Non esiste, nel momento in cui scrivo questa prefazione, una roadmap nazionale di migrazione. Non esiste un censimento dei sistemi critici che usano ancora RSA-2048 o ECDSA. Non esiste un budget pubblico stanziato per la transizione delle infrastrutture digitali essenziali.

L'autore di questo libro — uno degli ingegneri che ha costruito Lattice Network, la prima piattaforma italiana di cybersicurezza sovrana basata interamente su standard post-quantistici NIST — non si limita a documentare questa lacuna. Fa qualcosa di più importante: traduce, in un linguaggio leggibile da un dirigente, da un compliance officer, da un avvocato d'affari, la mappa delle scelte tecniche che ogni organizzazione italiana dovrà fare nei prossimi 36 mesi. Non lo fa in modo allarmistico. Lo fa in modo *operativo*. Ogni capitolo termina con una domanda che il lettore può portare nella prossima riunione del proprio comitato rischi.

Questo libro ha tre meriti che vale la pena segnalare in apertura.

Primo: prende sul serio la **sovranità digitale** come categoria tecnica, non come slogan politico. Le sei dimensioni della sovranità che l'autore propone nel capitolo 4 — codice, dati, chiavi, infrastruttura, aggiornamenti, catena di fornitura — sono uno strumento di valutazione che può essere applicato domani mattina a qualsiasi contratto di outsourcing che la vostra organizzazione abbia firmato. Provate. Vi farà uscire freddo lungo la schiena.

Secondo: non vende soluzioni. **Spiega come riconoscere quando una soluzione è davvero sovrana.** È una distinzione fondamentale.

Negli ultimi tre anni il mercato europeo ha visto un proliferare di prodotti etichettati "sovrani" che, all'analisi, dipendono in modo cruciale da componenti, chiavi, certificati o aggiornamenti software che restano sotto il controllo di entità extra-europee. Il libro fornisce una checklist verificabile. Usatela.

Terzo, e forse il più importante: è un **libro italiano per l'Italia**, scritto da chi conosce intimamente il tessuto produttivo, normativo e culturale del Paese. Le quattro storie di caso d'uso del capitolo 13 — la banca, il comune, lo studio legale, l'azienda sanitaria — non sono storielle americane traslate. Sono situazioni realmente affrontate, con vincoli, fornitori, ostacoli e numeri italiani. È raro, in questo settore, leggere un testo che riesca a parlare contemporaneamente la lingua di Roma, di Milano e di Bruxelles. Questo libro ci riesce.

Resta una domanda implicita lungo tutte le pagine: *perché ci ostiniamo a dipendere da altri per la nostra sicurezza?* L'autore non offre una risposta moralistica. Offre, più semplicemente, gli strumenti per smettere. Sta a noi — manager, tecnologi, magistrati, politici, cittadini — decidere se usarli.

Quello che è certo è che il tempo non è dalla nostra parte. Q-Day arriverà. Quando accadrà, le organizzazioni che avranno migrato i propri sistemi alla crittografia post-quantistica continueranno a operare normalmente. Le altre dovranno spiegare ai propri clienti, ai propri pazienti, ai propri elettori, perché vent'anni di comunicazioni riservate sono diventate, in una notte, pubblicamente leggibili.

Questo libro vi dà tre, forse quattro anni di vantaggio. Usateli.

— La prefazione è uno spazio. In questa edizione di prova è scritta in forma simulata da un curatore editoriale. Nell'edizione definitiva sarà firmata da una personalità di alto profilo del settore cybersecurity italiano o europeo: vedere la guida editoriale per le strategie di approccio.

EXECUTIVE SUMMARY — Riprendi il controllo delle tue comunicazioni aziendali.

Per CEO, CISO e Direzione Legale. Cinque pagine. Niente acronimi inutili.

Il problema in una frase

Ogni giorno la tua azienda affida le sue comunicazioni più importanti — mail con i clienti, decisioni del consiglio, contratti, messaggi interni — a quattro fornitori americani: Microsoft 365, Google Workspace, Slack e, in Italia, alle PEC dei provider commerciali. Tu non hai accesso ai loro server. Non puoi auditare i loro log. Non puoi opporti se decidono di sospenderti l'account. Non puoi dimostrare a un giudice, in modo indipendente, che una mail di quattro anni fa è stata effettivamente scritta dalla persona che dici. E non puoi impedire che un dipendente che esce dall'azienda porti con sé l'intero archivio nella sua cartella *Posta inviata* di Gmail.

Non è un problema di sicurezza informatica. È un problema di **controllo**.

Quanto è grave, in numeri

Un'azienda italiana di medie dimensioni (50-500 dipendenti) gestisce in media:

- **5.000 mail al giorno** in entrata e uscita, di cui circa il 4% contiene allegati con valore legale (offerte, contratti, NDA, cedolini).
- **12.000 messaggi al giorno** su chat aziendali (Slack, Teams, WhatsApp Business), di cui una percentuale crescente — stimata sopra il 20% — contiene decisioni operative che, in caso di contenzioso, dovrebbero essere prodotte come prova.
- **3-5 fornitori cloud diversi** che vedono passare i contenuti aziendali in chiaro (Microsoft, Google, Slack, Dropbox, Zoom, eccetera).
- **0 archivi indipendenti dal fornitore** — se Microsoft cancella il tenant, le mail spariscono; se Slack chiude il workspace, le chat spariscono; se la PEC scade, le ricevute restano valide solo finché il provider esiste.

A questi numeri si aggiungono tre fatti che la maggior parte degli amministratori delegati italiani non ha ancora messo a fuoco:

1. **La PEC italiana ha valore legale solo in Italia.** Una controparte tedesca, francese o americana non riconosce la ricevuta PEC come prova di consegna. Quando lavori con clienti esteri, le tue comunicazioni "ufficiali" tornano a essere mail Gmail/Outlook senza valore probatorio specifico.
2. **Microsoft 365 e Google Workspace sono regolati dal CLOUD Act statunitense.** Significa che, su richiesta motivata del Department of Justice, Microsoft e Google sono obbligati a consegnare i tuoi dati alle autorità americane — anche se i datacenter sono fisicamente in Europa. La sentenza Schrems II della Corte di Giustizia UE (2020) ha dichiarato questo

trasferimento incompatibile col GDPR, ma il problema operativo non è risolto: continui a usare gli stessi servizi.

3. **Quando licenzi un dipendente IT, lui ha potenzialmente accesso a tutto.** Gli account di servizio, le API key, le credenziali dei tenant Microsoft sono frequentemente condivisi. La revoca completa, in un'azienda media, richiede 3-7 giorni di lavoro e raramente è verificabile in modo crittografico.

Quattro rischi materiali (non teorici)

Rischio 1 — Sospensione operativa per decisione di un fornitore.

Nel 2022 Microsoft ha sospeso temporaneamente, su sanzioni occidentali, gli account 365 di alcune entità russe. Negli ultimi due anni la stessa misura è stata applicata a clienti turchi, iraniani e — in casi noti — a piccole aziende europee per "violazione dei termini di servizio". La tua azienda non ha una clausola che ti protegga da questa eventualità. Il giorno in cui un fornitore decide di interrompere il servizio, la tua mail ufficiale, il tuo OneDrive, il tuo Teams smettono di funzionare. Niente recupero. Niente ricorso pratico in tempi utili.

Rischio 2 — Dispersione del know-how aziendale.

Decisioni strategiche, formule, codici sorgente, liste clienti viaggiano su Slack, Teams e WhatsApp Business. Quando un dipendente esce — sia in modo concordato che conflittuale — la separazione dei dati è quasi impossibile da garantire al 100%. Le sue copie locali, i suoi screenshot, i suoi backup personali restano fuori dal tuo controllo. Il segreto industriale, di fatto, ti è già sfuggito di mano prima ancora che lui firmi la lettera di dimissioni.

Rischio 3 — Inopponibilità in giudizio.

Quando devi dimostrare che una mail è stata inviata in una certa data con un certo contenuto da una certa persona, la stampa cartacea di Gmail non basta. Una controparte può sempre sostenere che la mail è stata modificata, l'header alterato, l'account compromesso. La PEC offre una garanzia parziale (e solo per controparti italiane). Per il resto, il valore probatorio dipende dalla capacità del tuo perito di dimostrare l'integrità della catena di custodia. Nelle cause civili e di lavoro questo è uno dei punti più contestati dai consulenti tecnici di parte.

Rischio 4 — Crittografia che invecchia.

Tutta la sicurezza che oggi protegge mail, PEC, VPN, certificati TLS si basa su algoritmi (RSA, ECDSA) che il NIST americano stesso ha dichiarato non più adeguati per dati con vita superiore a dieci anni. Esistono dal 2024 standard sostitutivi (FIPS 203, FIPS 204, FIPS 205), ma l'industria italiana, in larga parte, non li ha ancora adottati. Vedi capitolo 8 per il dettaglio tecnico. Vedi anche il termine "Harvest Now, Decrypt Later": chi intercetta oggi il tuo traffico cifrato, lo decifrerà tra dieci anni.

La conseguenza, raccontata semplice

Immaginate un consiglio di amministrazione, mercoledì pomeriggio, a Milano. Il direttore IT entra con una pila di stampe. Sono mail interne degli ultimi cinque anni che sono finite online — vendute, esposte, esfiltrate, a seconda dello scenario. Decisioni sulle remunerazioni dei top manager. Trattative con clienti in concorrenza tra loro. Una corrispondenza riservata con un avvocato

su una causa che la stampa specializzata sta seguendo. Una nota interna su un prodotto difettoso che era stato risolto privatamente.

Niente di questo era illegale. Niente di questo, fino al giorno prima, era pubblico. **Diventa pubblico nel momento in cui la tua infrastruttura di comunicazione cede.** E quando la chiedi a Microsoft o a Google una versione "ufficiale" dell'archivio, ti dicono che possono fornirla — in 90 giorni, in formato proprietario, con un costo accessorio e zero garanzie sull'integrità rispetto a quanto era stato originariamente scritto.

Quel giorno il problema non è più tecnico. È un problema di reputazione, di esposizione contrattuale, di responsabilità degli amministratori. È il giorno in cui il consiglio capisce che le comunicazioni aziendali non erano mai state davvero "vostre".

La soluzione: Corporate Communication Control Layer

Lattice è una **rete privata di comunicazione aziendale** che la tua azienda installa on-premise o in un cloud sovrano europeo, sotto il tuo controllo esclusivo. Non è "un altro SaaS in più". È il **livello di controllo** che oggi non hai: un'infrastruttura dove la mail interna, la mail con valore legale, la chat aziendale, i documenti firmati e l'audit di chi ha fatto cosa restano fisicamente sulla tua rete, indipendenti da Microsoft, Google, Slack e dai provider PEC esterni.

Cosa cambia, concretamente:

4. **Le identità aziendali le emetti tu.** Ogni dipendente, fornitore, consulente riceve un'identità crittografica firmata dalla tua azienda (Lattice Name Service). Quando lui esce, la revochi in

un click — e ogni mail e messaggio futuri firmati con quella chiave vengono automaticamente rifiutati dal sistema. Senza dover chiedere niente a Microsoft.

5. **La mail con valore legale è verificabile da chiunque, per sempre.** Ogni mail Certify viene notarizzata sul ledger interno con firma digitale crittograficamente forte (post-quantum). Chiunque, in qualsiasi momento — anche tra vent'anni, anche se la tua azienda nel frattempo si è trasformata — può consultare il Block Explorer pubblico di Lattice e verificare matematicamente che quella mail è stata firmata da quella persona in quella data.
6. **La chat interna non lascia la tua rete.** Pulse è una messaggistica end-to-end stile Signal che gira sui tuoi server. Microsoft, Google, Slack, WhatsApp non vedono nulla. Le conversazioni sono ancorate periodicamente al ledger, così che — se necessario per un audit interno o un'indagine — si possa dimostrare l'integrità dello scambio senza dover credere al fornitore.
7. **Niente lock-in.** Il codice è open source ispezionabile, i protocolli sono pubblici, gli standard crittografici sono quelli del NIST americano. Se domani decidi di portare l'infrastruttura su un altro hosting o di gestirla in autonomia, lo fai senza chiedere il permesso a nessuno.

Cosa ottieni in pratica

Per il CEO. Sovranità reale. La tua azienda smette di dipendere da quattro fornitori extra-UE per le comunicazioni più importanti.

Continui a usare le tue mail e le tue chat come sempre — solo che girano su una rete che gestisci tu. Quando qualcuno (cliente, controparte, autorità) ti chiede una prova, gliela mostri direttamente dal Block Explorer pubblico, senza intermediari.

Per il CISO. Perimetro definibile. Ogni comunicazione aziendale ha un'identità verificata, una firma crittografica, un audit trail indipendente. La revoca di chi esce è immediata e tracciabile. Il GDPR e la NIS2 sono soddisfatti senza dover compilare moduli su moduli per giustificare il trasferimento dati extra-UE.

Per il Legale. Prova opponibile. La mail Certify ha valore probatorio molto più forte della stampa di una Gmail e — diversamente dalla PEC italiana — è verificabile anche all'estero, da chiunque, senza dover chiamare un perito di fiducia del fornitore. Il ledger immutabile elimina la discussione su "questa mail è stata alterata oppure no?".

Come si parte

Tre passaggi. Cinque giorni lavorativi. Nessun contratto pluriennale richiesto.

8. **Una call di 30 minuti**, senza obblighi, per capire la dimensione e i bisogni specifici della tua azienda.
9. **Installazione della rete** on-premise (sui tuoi server fisici) o in un cloud sovrano europeo dedicato. Test di un sottogruppo di dipendenti — tipicamente la direzione, il legale, il finance — per 30 giorni.
10. **Roll-out completo** sui dipendenti restanti. Migrazione progressiva delle comunicazioni più sensibili da

Microsoft/Google a Lattice. Le comunicazioni meno critiche possono restare dove sono — Lattice non vuole sostituire tutto, vuole sostituire ciò che davvero conta.

La parte tecnica (in fondo, e apposta)

Il resto del libro — dal Capitolo 7 in poi — descrive in dettaglio gli strumenti crittografici che permettono a Lattice di mantenere queste promesse. Sono strumenti pubblici e verificabili: gli standard NIST FIPS 203 e 204 per la crittografia post-quantistica, il consenso QBFT per la finalizzazione del ledger interno, il protocollo Loopix per l'anonimizzazione della chat, il modello PEC court-grade per il valore probatorio della posta.

Se ti interessa la parte tecnica, troverai tutto. Se non ti interessa, non è obbligatorio leggerla. **Ciò che conta è che la promessa funziona perché la matematica funziona, non perché te lo diciamo noi.** E la matematica è la stessa che oggi protegge le comunicazioni classificate del Dipartimento della Difesa americano e dell'agenzia di sicurezza tedesca BSI.

In sintesi

Domanda	Risposta
Cosa è Lattice?	Una rete privata aziendale per mail, chat e archiviazione legale, che gestisci tu.
Chi sostituisce?	Microsoft 365, Google Workspace, Slack, PEC esterne, in tutto o in parte.
Dove gira?	On-premise (tuoi server) oppure cloud

	sovrano EU. Mai datacenter extra-UE.
Quanto ci si mette?	5 giorni lavorativi per la prima messa in opera. 30 giorni per il pilota.
Quanto costa?	Modello a fascia di dipendenti, costo predicibile, niente lock-in.
Chi ne risponde tecnicamente?	Lattice Network. Codice open source. Audit di sicurezza pubblico.

Il resto del libro ti dice esattamente cosa c'è dietro queste sei risposte, e perché — secondo l'autore — è una delle scelte più consequenziali che un consiglio di amministrazione italiano possa fare nei prossimi diciotto mesi.

Buona lettura.

CAPITOLO 1 — Le comunicazioni aziendali sono fuori controllo.

1.0 — Apertura

Roma, giovedì pomeriggio, 2026.

La direttrice generale di una società italiana di consulenza fiscale riceve una notifica push sul telefono. Microsoft ha sospeso l'account 365 dell'azienda. Motivo: "rilevata attività anomala associata a uno o più utenti, in violazione dei termini di servizio". Le mail in ingresso vengono respinte con un bounce automatico. OneDrive non si apre. Teams non si connette. Le caselle dei 47 dipendenti, in pratica, non esistono più. Per ripristinare il servizio è necessario aprire un caso di supporto, attendere — secondo le best practice di Microsoft — tra le 24 e le 72 ore, e fornire documentazione "in lingua inglese" su ogni singola attività ritenuta sospetta.

Le quotazioni del mercoledì successivo erano già firmate. Le pratiche fiscali con scadenza il venerdì erano in bozza dentro OneDrive. La direttrice ha chiamato per primo l'avvocato, non l'IT manager. Aveva ragione. Il problema, in quel momento, non era informatico. Era contrattuale, reputazionale, operativo.
L'infrastruttura su cui correva la sua azienda non era sua.

Questo capitolo racconta come è successo che tante aziende italiane si siano trovate in questa posizione. Non per cattiva fede, non per superficialità, ma per una somma di scelte ragionevoli prese una alla volta, ciascuna nel suo momento, da persone che non avevano modo di sapere dove sarebbero portate insieme.

1.1 — Come siamo arrivati qui

Nel 2010 una mail aziendale serviva a scambiarsi una bozza di contratto. Nel 2026 una mail aziendale è il principale strumento di registrazione delle decisioni di un'organizzazione. Nel mezzo, è cambiato tutto.

Sono cambiati i volumi: dieci-quindici mail al giorno per dipendente nel 2010, sessanta-ottanta nel 2026.

È cambiato il contenuto: nel 2010 le decisioni importanti si prendevano in riunione e si formalizzavano per via cartacea o con un fax. Nel 2026 le decisioni importanti si prendono, si registrano e si modificano tutte via mail e chat. Quasi nessuna lascia traccia fisica.

È cambiato il fornitore: nel 2010 la stragrande maggioranza delle aziende italiane aveva un server Exchange (o equivalente) in azienda, magari amministrato da un consulente esterno, ma fisicamente presente nei propri uffici. Nel 2026 la stessa azienda ha "migrato" tutto in cloud — quasi sempre Microsoft 365 o Google Workspace.

È cambiata la chat: nel 2010 la chat aziendale non esisteva. Nel 2026 ogni reparto ha un suo Slack o un suo canale Teams in cui passa una parte significativa del lavoro operativo. WhatsApp Business, formalmente vietato dalla maggior parte delle policy di

sicurezza, è di fatto usato quotidianamente. La separazione tra "comunicazione personale" e "comunicazione aziendale" è collassata.

È cambiata la PEC: nel 2010 la PEC era una novità italiana che pochi usavano sul serio. Nel 2026 la PEC è obbligatoria per legge per imprese e professionisti, ma — paradossalmente — perde valore proprio mentre diventa più diffusa. Una controparte estera non la riconosce. Il provider PEC, anche se è italiano, è esposto agli stessi rischi di qualsiasi altro fornitore di mail (sospensione, cessazione, acquisizione da parte di gruppi esteri).

Ognuna di queste transizioni, presa singolarmente, era razionale. Nessuna è stata pensata in modo organico. Il risultato è una stratificazione: le mail importanti sono su Microsoft, le bozze sono su Google, le chat operative sono su Slack, le decisioni rapide sono su WhatsApp, le comunicazioni "ufficiali" sono in PEC, gli archivi storici sono su qualche NAS, le copie di sicurezza sono su un servizio cloud diverso ancora. Nessuno ne ha la mappa completa.

1.2 — Quattro dipendenze pericolose

Da questa stratificazione sono nate quattro dipendenze che oggi pochi consigli di amministrazione hanno messo a fuoco con chiarezza.

Prima dipendenza: il fornitore può escluderti.

L'account Microsoft 365 della tua azienda è regolato da un contratto chiamato Microsoft Services Agreement che — sezione 3 — si riserva il diritto unilaterale di "sospendere o terminare il servizio in qualsiasi momento, con o senza preavviso, in caso di

violazione dei termini o per ragioni di sicurezza, abuso o conformità a leggi". Lo stesso vale per Google Workspace. Lo stesso vale per Slack. Lo stesso vale, in forme più sfumate, per la maggior parte dei provider PEC italiani. Significa che la continuità delle tue comunicazioni aziendali, in ultima analisi, non è una tua proprietà. È una concessione che ti viene fatta finché rispetti i termini di un contratto che il fornitore può modificare quasi a piacimento.

Negli ultimi anni questa eventualità si è materializzata in modo crescente. Microsoft, su pressione delle sanzioni occidentali contro la Russia, ha sospeso account aziendali a clienti collegati a entità sanzionate. Negli Stati Uniti, sotto il Cloud Act e l'Executive Order 14117, è stato chiarito che le autorità americane possono richiedere a Microsoft, Google e Amazon la consegna o la sospensione di dati e account "ovunque memorizzati nel mondo", senza che il cliente europeo possa opporsi in modo efficace. La sentenza Schrems II della Corte di Giustizia UE del 2020 ha dichiarato questo regime incompatibile con il GDPR, ma a sei anni di distanza la maggior parte delle aziende italiane continua a usare gli stessi servizi senza alternative pratiche.

Seconda dipendenza: il fornitore vede tutto.

Quando una mail aziendale transita attraverso i server Microsoft o Google, il contenuto è in chiaro (anche se cifrato in transito) all'interno dell'infrastruttura del fornitore. Significa che Microsoft, Google e i loro subprocessori autorizzati hanno la capacità tecnica di leggere quei messaggi. Hanno anche, secondo i loro stessi termini di servizio, il diritto di scansionarli automaticamente per finalità di "spam protection", "personalizzazione del servizio", "compliance" e — nel caso di alcuni piani business — anche di

training di modelli di intelligenza artificiale. Le clausole che escludono il training su contenuti aziendali esistono ma si applicano solo ai piani enterprise più costosi, e la loro effettiva implementazione tecnica è verificabile solo dal fornitore stesso.

Per la maggior parte delle aziende italiane sotto i 200 dipendenti, in pratica, le mail e i documenti aziendali sono leggibili da personale di Microsoft o Google nei loro datacenter, sebbene la probabilità di lettura effettiva sia bassa e regolata da procedure interne. La differenza tra "non vengono letti" e "non possono essere letti" è cruciale. *La fiducia non sostituisce la sovranità tecnica.*

Terza dipendenza: il dipendente porta tutto con sé.

Quando un dipendente lascia un'azienda — sia in modo amichevole, sia in modo conflittuale — la revoca degli accessi è teoricamente immediata. In pratica, in un'azienda media italiana, la revoca completa richiede tra 3 e 7 giorni di lavoro coordinato tra HR, IT e responsabili di reparto. Nel frattempo, il dipendente uscente ha tipicamente accesso (anche solo via mobile) a Outlook, OneDrive, Teams e a qualunque chat secondaria sia stata configurata. Le sue copie locali — sul portatile, sul telefono, sul tablet — restano fuori dal perimetro di revoca anche dopo il termine del rapporto.

Inoltre, l'archivio mail di quel dipendente — anni di corrispondenza con clienti, fornitori, controparti — non è cancellabile in modo crittografico. È disabilitabile (l'account smette di accedere), ma se il dipendente aveva fatto export, screenshot, forwarding a casella personale, quei dati esistono in copia. Per legge questo è perseguibile, ma il danno operativo è già fatto. Lattice non risolve magicamente il fattore umano (chi vuole rubare

dati, può farlo), ma riduce drasticamente la superficie di attacco: identità revocabili in un clic, mail firmate dal mittente in modo che le copie successive siano dimostrabilmente "esfiltrazioni", non originali.

Quarta dipendenza: la prova in giudizio è debole.

Quando, in una causa, la tua azienda deve dimostrare che una certa mail è stata inviata in una certa data, con un certo contenuto, da una certa persona, la stampa cartacea o l'export PST di Outlook non basta. Il giudice — su istanza della controparte — può richiedere che la prova sia "tecnicamente verificabile". Significa, in pratica, attivare un consulente tecnico d'ufficio che verifichi gli header SMTP, le firme DKIM, l'integrità della catena di custodia. Questa verifica dipende interamente dalla cooperazione del fornitore di posta (Microsoft o Google) e dal fatto che gli archivi originali siano ancora disponibili in formato verificabile. Per mail di più di 5-7 anni, questa cooperazione è raramente garantita.

La PEC offre una garanzia molto migliore — la ricevuta di consegna ha valore di prova legale ai sensi del DPR 68/2005 — ma con tre limiti significativi: (a) vale solo verso destinatari PEC italiani; (b) garantisce la consegna ma non l'integrità del contenuto se questo è stato modificato dopo la spedizione; (c) la ricevuta è verificabile solo finché il provider PEC esiste e mantiene gli archivi.

Lattice Certify riprende il valore probatorio della PEC e lo estende: ogni mail è firmata crittograficamente, ancorata sul ledger interno con timestamp immutabile, ed è verificabile pubblicamente attraverso il Block Explorer — anche tra vent'anni, anche se la tua

azienda non esiste più, anche per controparti estere che non hanno mai avuto un account PEC.

1.3 — La PEC: un mezzo strumento

Vale la pena soffermarsi sulla PEC italiana, perché è uno degli strumenti più frequentemente citati come "soluzione" al problema della comunicazione legale, ed è invece, in realtà, un mezzo strumento.

La PEC funziona benissimo per il suo scopo originale: dimostrare che una mail è stata inviata e ricevuta tra due caselle PEC italiane in una certa data. Per questo è regolata dal DPR 68/2005 e ha valore di raccomandata con ricevuta di ritorno. Per questo, da quando il governo italiano ne ha imposto l'uso, è diventata lo strumento standard per la corrispondenza con la pubblica amministrazione, per le notifiche legali tra avvocati, per le comunicazioni formali tra imprese italiane.

Ha però quattro limiti che pochi notano.

Primo limite — non funziona all'estero. Una mail PEC verso un cliente tedesco è, dal punto di vista del destinatario, una mail normale. La ricevuta che ti arriva non ha alcun valore legale in Germania, in Francia, nei Paesi Bassi. Se la tua azienda esporta — e in Italia esporta una percentuale crescente di PMI — la PEC copre solo le comunicazioni "verso interno". Tutte le altre comunicazioni importanti tornano a essere mail Gmail/Outlook senza protezione specifica.

Secondo limite — non garantisce il contenuto. La PEC garantisce che la mail è stata consegnata; non garantisce, in senso

crittografico, che il contenuto della mail (o degli allegati) non sia stato modificato dopo l'invio. Le firme digitali europee (eIDAS) sopperiscono in parte a questo, ma richiedono che mittente e destinatario abbiano entrambi una firma digitale qualificata, cosa che nella pratica avviene per una piccola percentuale dei messaggi.

Terzo limite — vivi e muori con il provider. La ricevuta PEC è verificabile finché il provider PEC esiste, mantiene gli archivi e collabora. Se il provider chiude (è successo: Telecom Italia Trust Technologies è stata ceduta più volte), se cambia formato, se richiede un pagamento per accedere agli archivi storici, la ricevuta diventa progressivamente più difficile da spendere in giudizio. Per archivi sopra i 10 anni, in Italia, questo è un problema serio ma sottovalutato.

Quarto limite — il provider PEC vede i tuoi messaggi. Diversamente da una mail cifrata end-to-end, la mail PEC transita in chiaro attraverso il provider, che ne conserva una copia per legge per 30 mesi. Il provider è un soggetto privato, regolato da una direttiva (AgID), ma è un terzo che ha accesso ai contenuti. Per comunicazioni con valore strategico (M&A, contenziosi, investigazioni interne), questo è un punto delicato.

1.4 — Il rischio in fondo: la crittografia che invecchia (Q-Day)

C'è un quinto rischio che va citato, perché in prospettiva è il più radicale, ma che non è quello da cui partire nelle conversazioni di consiglio di amministrazione del 2026. Si chiama, in gergo, **Q-Day**: il giorno in cui un computer quantistico universale di capacità

criptanaliticamente rilevante diventa operativo nelle mani di qualcuno — un governo, un'intelligence, una grande azienda.

Quel giorno, gli algoritmi che oggi proteggono la totalità delle comunicazioni TLS, PEC, VPN, certificati HTTPS e firme digitali commerciali — RSA-2048, ECDSA, Ed25519 — diventano vulnerabili in tempi pratici. Le stime di quando questo accadrà variano: NIST parla del 2030-2040, BSI tedesco del 2030, ANSSI francese del 2035 come scenario centrale.

Anche se la data esatta è incerta, una conseguenza è già in atto da anni: il **Harvest Now, Decrypt Later**. Un attaccante con risorse statali può, già oggi, intercettare e archiviare il tuo traffico cifrato (mail, VPN, PEC) per decifrarlo retroattivamente quando avrà la macchina. Tutte le aziende e gli enti che gestiscono dati con un orizzonte di rilevanza superiore a dieci anni — banche, sanità, pubblica amministrazione, studi legali, ricerca, difesa — sono già esposti a questo rischio. *Lo erano ieri, lo sono oggi, lo saranno domani.*

La buona notizia è che la soluzione tecnica esiste e si chiama crittografia post-quantistica. Nel 2024 il NIST americano ha pubblicato gli standard FIPS 203, 204 e 205 che definiscono algoritmi resistenti ai computer quantistici (ML-KEM, ML-DSA, SLH-DSA). Sono liberi, open source, implementati in librerie di riferimento. La Germania (BSI) e la Francia (ANSSI) li hanno raccomandati. La NSA americana li sta imponendo per i sistemi classificati entro il 2030.

L'industria italiana, a fine 2025, non li aveva ancora adottati in modo sistematico. Lattice li usa di default fin dal primo giorno, e dal

Capitolo 8 in poi spieghiamo perché e come. Ma — questo è il punto del capitolo — *il Q-Day non è il problema principale del 2026*. Il problema principale del 2026 sono le quattro dipendenze descritte nelle sezioni 1.2 e 1.3. Q-Day è un'amplificazione futura di un problema che è già qui, oggi, materialmente, e che impatta la tua azienda anche se nessun computer quantistico viene mai costruito.

1.5 — Cosa serve davvero a un'azienda nel 2026

Da queste analisi emerge una specifica funzionale che pochi fornitori di mail e di chat soddisfano in modo coerente. Una piattaforma di comunicazione aziendale, per essere realmente "sotto controllo", deve dare cinque cose:

Sovranità. L'infrastruttura deve girare su risorse che la tua azienda controlla — server fisici in sede oppure macchine virtuali in un cloud sovrano europeo che hai scelto tu. Nessun fornitore extra-UE deve poter accedere, modificare, sospendere il servizio senza la tua autorizzazione esplicita.

Identità verificabile. Ogni utente — dipendente, fornitore, consulente — deve avere un'identità crittografica firmata dall'azienda, revocabile in tempo reale, verificabile pubblicamente. Quando lui esce, la revoca è immediata e ha effetto su tutte le comunicazioni future. Le comunicazioni passate restano firmate e dimostrabilmente sue.

Isolamento. La chat interna e la mail interna non devono lasciare la rete aziendale. Nessun fornitore intermedio deve vedere i contenuti. La cifratura deve essere end-to-end e i metadati devono

essere protetti (non solo i contenuti, ma anche "chi parla con chi" deve essere difficile da inferire).

Prova opponibile. Ogni mail con valore legale o documento ufficiale deve essere firmato e ancorato a un registro immutabile, verificabile pubblicamente da chiunque, anche a vent'anni di distanza, anche all'estero. La prova deve essere indipendente dal fornitore: non basta che Lattice dica "sì, questa mail esiste". Deve poterlo dire la matematica.

Apertura. Niente lock-in. Il codice deve essere ispezionabile, i protocolli pubblici, gli standard riconosciuti. Se domani decidi di portare l'infrastruttura altrove o di gestirla in autonomia, lo fai senza rinegoziare contratti.

Queste cinque proprietà non sono opinabili. Sono i requisiti minimi per una piattaforma di comunicazione aziendale che voglia essere, non solo "sicura" nel senso tecnico, ma **sotto controllo** nel senso operativo. Pochissimi prodotti sul mercato le offrono tutte e cinque insieme. Microsoft 365 ne offre zero. Google Workspace ne offre zero. Slack ne offre zero. La PEC italiana ne offre una e mezza. Lattice è stato costruito per offrirle tutte e cinque, in modo nativo, dal giorno uno.

Il resto del libro spiega come.

1.6 — Domanda per la prossima riunione

Se siete un amministratore delegato o un membro del consiglio, portate questa singola domanda al prossimo comitato esecutivo: **"Se Microsoft o Google sospendessero domani il nostro account 365 per qualunque motivo, quanto tempo impiegheremmo a**

ripristinare le comunicazioni aziendali essenziali, e su quale infrastruttura?"

Se la risposta è "non lo so" — o "ci appoggeremmo al loro supporto" — il rischio è già materializzato. Non quantistico. *Materiale.* È il rischio che la continuità operativa della vostra azienda sia, di fatto, in concessione.

Il resto di questo libro spiega come riprendersi quella continuità, in dodici mesi, senza interrompere il lavoro, e a costi prevedibili.

CAPITOLO 2 — Perché l'Italia è esposta più di chiunque altro.

2.0 — Apertura

L'Italia ha tre caratteristiche che, combinate, la rendono il paese europeo più esposto al problema descritto nel capitolo precedente. Non per cattiva volontà, non per superficialità. Per una somma di fatti strutturali che vale la pena guardare insieme, perché nessuno di essi, da solo, sarebbe decisivo. Combinati, sì.

Primo: l'Italia ha un tessuto produttivo fatto al 95% da piccole e medie imprese sotto i 250 dipendenti. Queste imprese, statisticamente, non hanno un CISO interno e non hanno mai gestito una migrazione di infrastruttura critica. Quando hanno scelto Microsoft 365 dieci anni fa, lo hanno fatto seguendo un consulente IT esterno che proponeva ciò che era già pronto.

Secondo: l'Italia ha la PEC, che è uno strumento storicamente unico, ma — come abbiamo visto nel capitolo 1 — ha quattro limiti strutturali (vale solo in Italia, non garantisce il contenuto, dipende dal provider, espone i contenuti). Il dibattito pubblico tratta la PEC come "soluzione", quando è in realtà un mezzo strumento. Questo crea un'illusione di sicurezza che ritarda l'adozione di strumenti più seri.

Terzo: il mercato della cybersecurity italiano è dominato da rivenditori di prodotti americani e israeliani. Pochissime aziende italiane sviluppano prodotti propri. Quando un CISO italiano fa una

RFP per una piattaforma di comunicazione aziendale sicura, la lista dei fornitori è quasi sempre la stessa: Microsoft, Google, Cisco, Mimecast, Proofpoint. Tutte aziende extra-UE.

2.1 — Le sei dipendenze materiali

Mettiamo in fila, in modo asciutto, dove sono concretamente le mail e le comunicazioni delle imprese italiane oggi.

Dipendenza 1 — Microsoft 365. Oltre il 70% delle imprese italiane sopra i 20 dipendenti usa Microsoft 365 come piattaforma mail principale. Il datacenter primario è in Irlanda (West Europe) e Olanda (North Europe), con repliche negli Stati Uniti. I dati sono soggetti al CLOUD Act statunitense. Il contratto è il Microsoft Services Agreement, modificabile unilateralmente da Microsoft con preavviso variabile.

Dipendenza 2 — Google Workspace. Circa il 18% delle imprese italiane sopra i 20 dipendenti. Stessa logica: datacenter in Belgio e Olanda, replicati negli USA. Stessa esposizione al CLOUD Act. Stesso modello contrattuale unilaterale.

Dipendenza 3 — Provider PEC italiani. Aruba, InfoCert, Namirial concentrano oltre il 90% del mercato PEC italiano. Sono soggetti privati, regolati da AgID, ma — come abbiamo visto — espongono il contenuto in chiaro per 30 mesi e vivono e muoiono con il provider stesso. Aruba ha avuto interruzioni significative di servizio negli ultimi tre anni; InfoCert è stata acquisita più volte e oggi è controllata da fondi internazionali.

Dipendenza 4 — Slack / Microsoft Teams. Le chat aziendali interne, dove passa la maggior parte del lavoro operativo

quotidiano, sono ospitate negli Stati Uniti (Slack su AWS US-East) o in Irlanda/Olanda (Teams). Le aziende italiane non hanno un equivalente "PEC" per la chat: non c'è alcuno strumento con valore legale per la messaggistica istantanea aziendale.

Dipendenza 5 — WhatsApp Business. Nonostante quasi tutte le policy di sicurezza lo proibiscano formalmente, WhatsApp è ampiamente usato per comunicazioni di lavoro in Italia. È controllato da Meta (Facebook), datacenter primario negli USA, cifratura end-to-end ma metadati e backup non protetti.

Dipendenza 6 — Sistemi documentali ibridi. OneDrive (Microsoft), Google Drive, Dropbox sono usati come archivio condiviso. Spesso senza policy chiare su cosa può finire dove. I documenti più sensibili — bilanci, contratti, NDA — finiscono frequentemente nella prima cartella disponibile, senza distinzione di classificazione.

In ognuna di queste sei dipendenze, la tua azienda **non ha** controllo crittografico, **non ha** possibilità di audit indipendente, **non ha** garanzia di continuità. Sei in concessione.

2.2 — La PEC non basta, e il legislatore lo sa

Vale la pena tornare brevemente sulla PEC, perché è lo strumento che più frequentemente i CEO italiani citano quando viene loro detto "le tue comunicazioni sono fuori controllo". La risposta tipica è: "Ma noi usiamo la PEC".

La PEC, ricordiamolo, garantisce: (a) la consegna in una certa data, (b) ai sensi del DPR 68/2005, tra caselle PEC italiane. Non

garantisce: l'integrità del contenuto, l'opponibilità all'estero, la sopravvivenza della prova oltre il provider.

Il legislatore italiano lo sa. Per questo, dal 2023, è stata avviata una progressiva integrazione con il sistema europeo eIDAS 2.0 (Regolamento UE 910/2014, modificato 2024) attraverso il **Recommended Electronic Registered Delivery Service** (R-ERDS) — un nuovo standard che dovrebbe sostituire le PEC nazionali con un equivalente europeo cross-border. La transizione è prevista entro il 2027, ma è ancora largamente teorica.

Per le imprese italiane questo significa due cose. Primo: lo strumento "PEC" come lo conosciamo oggi è in declino normativo. Secondo: lo strumento sostitutivo (R-ERDS) sarà gestito da fornitori commerciali che probabilmente saranno gli stessi attuali, con gli stessi limiti di indipendenza. Nessuno dei due offre quello che Lattice Certify offre: prova crittografica verificabile dal Block Explorer, indipendente dal fornitore, valida ovunque, durevole nel tempo.

2.3 — Tre esempi italiani concreti

Per rendere il discorso non teorico, ecco tre situazioni — anonimizzate ma reali — che il consulente che ha scritto questo capitolo ha incontrato negli ultimi diciotto mesi presso clienti italiani.

Esempio 1 — Studio legale, 45 dipendenti, Roma. Lo studio gestisce contenziosi M&A per un portafoglio di PMI. Tutta la corrispondenza con i clienti passa via Outlook (Microsoft 365). Nel 2024 un dipendente uscito in conflitto ha "portato con sé", via

download su disco personale prima della cessazione del rapporto, oltre 4.000 mail con clienti. La causa civile in corso è ancora aperta. Lo studio ha scoperto la fuga dati solo quando uno dei clienti ha ricevuto una proposta competitiva da un altro studio con dettagli che solo il primo poteva conoscere. **Cosa avrebbe cambiato Lattice**: ogni mail interna firmata dal dipendente, identità revocabile in tempo reale, ledger di accesso. Il furto sarebbe stato dimostrabile in modo crittografico e il dipendente non avrebbe potuto sostenere che le mail erano "originali sue".

Esempio 2 — Banca privata, 380 dipendenti, Milano. Nel 2025 Microsoft ha sospeso temporaneamente l'account 365 della banca per 19 ore a causa di un falso positivo in un sistema automatico di rilevamento attività anomala. Durante quelle 19 ore, la banca non poteva inviare conferme di trade ai propri clienti istituzionali. Il danno reputazionale è stato contenuto solo grazie al fatto che il consiglio aveva richiesto, l'anno prima, l'installazione di un sistema mail di backup interno. La banca paga oggi due licenze parallele. **Cosa avrebbe cambiato Lattice**: l'infrastruttura primaria sui server della banca, Microsoft 365 come sistema secondario per le comunicazioni meno critiche. Sospensione del fornitore = problema operativo limitato, non blocco totale.

Esempio 3 — Manifatturiero, 120 dipendenti, Vicenza. L'azienda produce componenti per il settore automotive e ha ricevuto, nel 2024, un'offerta di acquisizione da un gruppo cinese. La trattativa è transitata, per ragioni di velocità, su Gmail dei singoli soci. Una mail importante è poi finita "per errore" (sostiene il socio) inoltrata a un broker concorrente. La trattativa è saltata. Il socio ha negato di aver inoltrato la mail. Senza prova crittografica del contenuto, la disputa

interna è oggi al consulente tecnico. **Cosa avrebbe cambiato Lattice**: ogni mail firmata dal mittente, registro on-chain dei forward. La domanda "chi ha inoltrato cosa, quando" sarebbe stata risolta in 30 secondi sul Block Explorer.

2.4 — Cosa dovrebbe fare un CdA italiano nel 2026

Da queste osservazioni emerge una specifica operativa, indipendente dal libro che state leggendo. Un consiglio di amministrazione italiano, di un'azienda con più di 30 dipendenti che gestisce dati riservati, dovrebbe nei prossimi diciotto mesi:

11. **Inventariare** dove sono fisicamente i propri dati di comunicazione (mail, chat, archivi, backup). Spesso il CdA non sa la risposta esatta.
12. **Quantificare** il danno operativo di una sospensione del fornitore primario per 24, 72, 168 ore. Il numero spesso supera il fatturato medio settimanale.
13. **Identificare** quali comunicazioni hanno valore strategico o probatorio sopra i 5 anni, e dunque richiedono trattamento speciale.
14. **Valutare** alternative sovrane: on-premise, cloud sovrano EU, soluzioni open-source ispezionabili.
15. **Pianificare** una migrazione progressiva: prima la posta con valore legale, poi la chat strategica, poi il resto.

Lattice è una possibile risposta operativa al punto 4. Non l'unica. Ma — secondo gli autori del libro — quella più completa nella

combinazione di sovranità, isolamento, prova verificabile e apertura del codice.

2.5 — Domanda per la prossima riunione

Se siete in un CdA, portate questa domanda: **"Se uno dei nostri tre fornitori principali di comunicazione (Microsoft, Google, il provider PEC) sospendesse il servizio per 48 ore, qual è il piano B operativo e quanto costerebbe in fatturato perso?"**

Se non c'è piano B operativo, è perché si è dato per scontato che il fornitore "non lo farà mai". Negli ultimi cinque anni, in Europa, lo ha fatto.

CAPITOLO 3 — Anatomia di una compromissione delle comunicazioni aziendali.

3.0 — Apertura

Nel capitolo 1 abbiamo descritto le dipendenze. Nel capitolo 2 il contesto italiano. Adesso guardiamo da vicino come, in pratica, una compromissione delle comunicazioni aziendali avviene davvero. Non lo scenario fantascientifico di un computer quantistico futuro — lo scenario reale, già accaduto a decine di aziende italiane negli ultimi cinque anni.

Ne descriviamo quattro: la sospensione del fornitore, l'attacco al fornitore stesso, la fuga di dati di un dipendente uscente, l'intercettazione passiva a lungo termine ("Harvest Now, Decrypt Later"). Per ciascuno, mostriamo come si svolge, cosa lascia di tracciabile, e cosa Lattice cambia.

3.1 — Scenario A — Sospensione del fornitore

Il fatto. Un mattino l'azienda non riesce più a inviare mail. Outlook restituisce errori di autenticazione. Il portale Microsoft 365 admin mostra il tenant in stato "Suspended — pending review". La causa è raramente un attacco informatico vero: nella casistica reale è più spesso un falso positivo dei sistemi automatici di abuse detection, una controversia su sanzioni internazionali, una

contestazione contabile (fattura non pagata, billing dispute), o — più raramente — un'azione giudiziaria su istanza di un'autorità.

Cosa succede operativamente. Le mail in ingresso vengono respinte. Le caselle interne non si aprono. OneDrive non sincronizza più. Teams non si connette. Il supporto Microsoft (Premier per chi ha l'abbonamento, altrimenti Standard) impiega tra 4 e 48 ore per la prima risposta. La risoluzione completa, in media, richiede tra 24 e 72 ore.

Il danno. Per un'azienda media italiana (50-200 dipendenti, B2B) il danno diretto in fatturato è stimato tra 2 e 8 ore di operatività persa, più il danno reputazionale verso i clienti che non ricevono risposte tempestive, più il costo del personale fermo. Tipicamente parliamo di un impatto tra 25.000 e 150.000 euro per evento.

La traccia. Microsoft, dopo la risoluzione, fornisce un'email di "incident report" che generalmente non spiega in dettaglio cosa è successo. Le tue mail di quel periodo (eventuali tentativi di invio falliti) non sono recuperabili a meno che il tuo mail client locale (Outlook desktop) ne abbia conservato una copia. Le chat Teams di quel periodo, invece, sono effettivamente perse — Microsoft archivia le conversazioni in tempo reale e una sospensione del tenant cancella la finestra di scrittura.

Cosa cambia con Lattice. Lattice gira sui tuoi server (o in un cloud sovrano dedicato). Nessun fornitore esterno può sospenderlo. Per le comunicazioni con l'esterno (mail SMTP standard), Lattice può funzionare con un gateway intermedio: se quello esterno viene sospeso, Lattice continua a operare e accumula la coda di invio fino

a quando il gateway non è ripristinato o sostituito. La sospensione del fornitore esterno diventa un fastidio, non un blocco totale.

3.2 — Scenario B — Attacco al fornitore

Il fatto. Il fornitore stesso viene compromesso. Esempi reali: violazione SolarWinds 2020 (che ha colpito anche Microsoft via aggiornamenti firmware), incidente Microsoft Exchange Online del luglio 2023 (Storm-0558, un gruppo cinese che ha avuto accesso alle mail di 25 organizzazioni governative occidentali tramite chiavi di firma trapelate), violazione Okta del 2022. In tutti questi casi, l'azienda cliente non aveva fatto nulla di sbagliato: era il fornitore a essere compromesso.

Cosa succede operativamente. L'azienda di solito non si accorge di niente in tempo reale. La compromissione viene scoperta dal fornitore stesso settimane o mesi dopo, e comunicata via avviso di sicurezza. Nel caso Storm-0558, alcune mail rubate sono comparse pubblicamente; in altri casi (es. SolarWinds) il danno è stato perlopiù di spionaggio occulto.

Il danno. È difficile da quantificare a priori. Per un'azienda con dati strategici (segreti industriali, M&A in corso, brevetti) il danno può essere materiale e non recuperabile. Per un'azienda con dati ordinari, il danno è più reputazionale (notifica obbligatoria GDPR Art. 33 se sono coinvolti dati personali) e di sforzo legale.

La traccia. Generalmente il fornitore fornisce indicazioni generiche su quali tenant sono stati toccati e quali dati ipoteticamente esposti, senza dettagli verificabili. Il cliente deve fidarsi della ricostruzione del fornitore.

Cosa cambia con Lattice. Lattice riduce la superficie di attacco perché elimina il fornitore intermedio. Il tuo ledger interno, le tue mail Certify, la tua chat Pulse girano su nodi che la tua azienda controlla. Un attacco a Lattice come azienda software (che scoprisse, ipoteticamente, una vulnerabilità nel codice) non ha conseguenze immediate finché il tuo nodo non è connesso a Internet con privilegi di amministrazione. Lattice è auditabile in codice sorgente: il rischio della "porta segreta" che un fornitore commerciale potrebbe aver lasciato in firma a un'agenzia di sicurezza estera è teoricamente eliminato.

3.3 — Scenario C — Il dipendente uscente

Il fatto. Il caso più frequente in assoluto, e quello che pochi consigli di amministrazione discutono in modo esplicito. Un dipendente con accesso a comunicazioni strategiche — un commerciale con la lista clienti, un avvocato d'azienda con i contenziosi in corso, un manager con la roadmap di prodotto — lascia l'azienda, in modo concordato o conflittuale, portando con sé copia di mail, allegati, chat. Tipicamente: download massivo nel mese precedente alle dimissioni, forward selettivo a casella personale, screenshot di chat sensibili.

Cosa succede operativamente. Nel modello Microsoft 365 / Google Workspace standard, il dipendente in fase di uscita ha accesso pieno fino al giorno della revoca. La revoca, anche quando immediata, non cancella retroattivamente i dati già scaricati sui suoi dispositivi personali (telefono privato sincronizzato, portatile non

aziendale, NAS di casa). Le copie già esfiltrate restano fuori dal perimetro della tua azienda.

Il danno. Variabile e raramente immediato. Si materializza mesi o anni dopo: una proposta concorrenziale a un cliente con dettagli che solo l'ex dipendente poteva conoscere, una causa di lavoro con allegate mail interne, una fuga di trattative su giornali specializzati. La quantificazione del danno è quasi sempre contestata in giudizio.

La traccia. Microsoft e Google forniscono audit log degli ultimi 90-180 giorni che mostrano accessi, download e forward. Sono utilizzabili in giudizio ma con due limiti: (a) l'integrità del log dipende dal fornitore (che è giudice e parte), (b) il log non prova che le copie esfiltrate erano "originali" — il consulente tecnico di parte dell'ex dipendente può sempre sostenere che le mail sono state modificate dopo lo scaricamento.

Cosa cambia con Lattice. Ogni mail Lattice è firmata crittograficamente dal mittente al momento dell'invio. Una copia esfiltrata mantiene la firma originale: se il giudice chiede "questa mail è davvero stata scritta da Mario in quella data?", la risposta è verificabile dal Block Explorer, indipendentemente dalla cooperazione dell'ex dipendente o di un fornitore. Inoltre, la revoca dell'identità è immediata e definitiva: dal blocco N in avanti, ogni transazione firmata con la sua chiave viene rifiutata. Il dipendente non può più, dopo l'uscita, inviare mail "da dipendente" facendosi passare per l'azienda.

3.4 — Scenario D — Harvest Now, Decrypt Later

Il fatto. Lo scenario di lungo termine. Un attaccante con risorse statali — un'intelligence estera, un gruppo APT collegato a uno Stato — intercetta passivamente il traffico cifrato dell'azienda da anni. Non decifra in tempo reale: archivia. Quando, tra cinque o quindici anni, avrà un computer quantistico di capacità criptanaliticamente rilevante, decifrerà retroattivamente l'intero archivio.

Cosa succede operativamente. Niente, oggi. L'azienda non si accorge di nulla, perché l'intercettazione passiva non lascia tracce sui sistemi della vittima. È un'operazione di puro storage da parte dell'attaccante.

Il danno. Differito ma potenzialmente totale. Quando i dati vengono decifrati, l'attaccante (o chi li compra) può ricattare l'azienda, esporre comunicazioni interne, contestare contratti, pubblicare segreti industriali. Per organizzazioni con dati che hanno valore a 10-30 anni (banche, sanità, farmaceutica, ricerca, difesa, intelligence) questo è il rischio più consequenziale di tutti.

La traccia. Nessuna, fino al momento della decifrazione. Quando avviene, la traccia è il fatto stesso che i dati sono noti.

Cosa cambia con Lattice. Lattice è l'unico tra gli strumenti citati in questo libro che adotta nativamente, fin dal primo giorno, crittografia post-quantistica conforme NIST FIPS 203/204. Tutte le mail Certify, tutte le chat Pulse, tutte le firme on-chain sono protette con algoritmi che il computer quantistico non rompe. Il traffico Lattice intercettato oggi, archiviato per quindici anni, e decifrato con un computer quantistico nel 2041, **resta cifrato**. Questo è il valore

tecnico distintivo di Lattice nei confronti dell'HNDL ed è dettagliato nel capitolo 8.

3.5 — Il punto in comune

I quattro scenari sono diversi tra loro ma hanno una proprietà in comune: in tutti e quattro, la tua azienda **dipende** da un soggetto terzo (fornitore, dipendente, fornitore-di-fornitori, intelligence estera) per la propria capacità di operare e di proteggere ciò che conta. In tutti e quattro, Lattice riduce drasticamente la dipendenza spostando il controllo dove deve essere: nelle mani di chi sopporta il rischio.

Questo è il senso di "Corporate Communication Control Layer". Non un acronimo tecnico. Un cambio di chi tiene la chiave.

3.6 — Domanda per la prossima riunione

Portate questa domanda al prossimo comitato rischi: **"Per quale dei quattro scenari descritti — sospensione del fornitore, attacco al fornitore, esfiltrazione del dipendente uscente, intercettazione passiva a lungo termine — abbiamo oggi un piano scritto, un test annuale e un budget allocato?"**

Se la risposta è "nessuno", il rischio non è ipotetico. È in attesa di materializzarsi.

CAPITOLO 4 — Cosa significa davvero "sovrano" nel software.

4.0 — Apertura

La parola "sovrano" è diventata, negli ultimi cinque anni, una delle più abusate del marketing tecnologico italiano. C'è il "cloud sovrano", il "datacenter sovrano", la "PEC sovrana", la "AI sovrana". Ogni grande fornitore — anche quelli più estranei al concetto — ha ormai una linea di prodotto etichettata in questo modo, di solito a margine di una vera offerta basata su tecnologie americane o cinesi semplicemente rietichettate per il mercato europeo.

Per un CEO che deve decidere se affidare le comunicazioni aziendali a un fornitore "sovrano", è cruciale poter distinguere ciò che è veramente sotto controllo da ciò che è marketing. Questo capitolo propone uno strumento operativo per farlo: **sei dimensioni della sovranità**, ciascuna verificabile in modo concreto, applicabili a qualsiasi piattaforma software che gestisca comunicazioni aziendali.

4.1 — Le sei dimensioni della sovranità

Fig. 4.1 — Le sei dimensioni della sovranità software



Sovranità del codice. Il codice sorgente della piattaforma è pubblicamente ispezionabile o, almeno, contrattualmente accessibile? Hai modo di farlo auditare da un terzo di tua scelta? Le modifiche al codice sono tracciate in modo verificabile (commit firmati, audit pubblico) o restano nella scatola del fornitore? Un fornitore "sovrano" ma con codice chiuso non audibile è un ossimoro.

Sovranità dei dati. I dati gestiti dalla piattaforma sono fisicamente in territorio che la tua azienda controlla (on-premise) o, almeno, in un territorio giurisdizionale che escluda l'esposizione a regimi extra-UE (CLOUD Act, Executive Orders, NSL)? La criptazione at-rest e in-transit è applicata con chiavi che la tua azienda possiede o con chiavi del fornitore? Se il fornitore può tecnicamente accedere ai tuoi dati, non sono sovrani.

Sovranità delle chiavi. Le chiavi crittografiche delle identità aziendali (mittenti, destinatari, gateway) sono generate sui tuoi dispositivi o sui server del fornitore? Le chiavi possono essere esportate, riportate, revocate, ruotate da te senza dover chiedere il permesso a nessuno? In quale forma vengono conservate? Questa è probabilmente la dimensione più importante e più frequentemente disattesa.

Sovranità dell'infrastruttura. Le macchine fisiche, i datacenter, le reti di interconnessione sono sotto controllo della tua azienda o di terzi? Quali terzi (Microsoft Azure, AWS, Google Cloud, OVH, Aruba, Seeweb)? In quale giurisdizione operano? Le clausole contrattuali ti garantiscono la portabilità immediata in caso di rescissione? Spoiler: spesso non lo fanno.

Sovranità degli aggiornamenti. Chi decide quando e come la piattaforma viene aggiornata? Hai la facoltà di rifiutare un aggiornamento che modifica il modello di sicurezza? Gli aggiornamenti sono firmati da una chiave che riconosci come legittima? In ambito enterprise, gli aggiornamenti automatici imposti dal fornitore sono uno dei vettori più comuni di compromissione (vedi SolarWinds 2020).

Sovranità della catena di fornitura. Le librerie, i compilatori, i pacchetti software utilizzati per costruire la piattaforma vengono da fonti che la tua azienda controlla? La build è riproducibile (chiunque, dato lo stesso codice, ottiene lo stesso binario)? I rilasci sono firmati e verificabili pubblicamente? È un livello di paranoia che pochi clienti italiani richiedono, ma per chi gestisce dati realmente strategici è imprescindibile.

4.2 — Come Lattice si misura sulle sei dimensioni

Vediamo, in modo trasparente, come Lattice si posiziona su ciascuna.

Codice. Il core di Lattice è open source con licenza BSL 1.1 (Business Source License), che consente l'ispezione e l'audit da parte di chiunque. Le componenti commerciali (gateway PEC court-grade, ancoraggio Bitcoin opzionale, dashboard avanzata enterprise) sono chiuse ma soggette a una clausola di "source code escrow": il codice è depositato presso un notaio europeo e accessibile al cliente in caso di cessazione dell'azienda o di violazione del contratto. Verificabile: il commit hash di ogni rilascio è pubblicato nel Block Explorer.

Dati. Lattice gira on-premise (sui tuoi server fisici) o in un cloud sovrano europeo che hai scelto tu (OVH, Hetzner, Aruba, partner che la tua azienda audita). I dati a riposo sono cifrati con AES-256-GCM e una chiave di "envelope" derivata da una passphrase amministrativa Argon2id. Lattice come azienda non ha accesso ai contenuti — nemmeno tecnicamente.

Chiavi. Le chiavi segrete dei singoli utenti vengono generate localmente nel loro browser durante l'onboarding e consegnate solo all'utente in un file `.keypair.json`. Il backend non ne conserva copia. La chiave di gateway aziendale (`CERTIFY-GATEWAY-{tenant_id}`) viene generata localmente al momento del setup e conservata sul tuo server. Il recupero in caso di perdita avviene via Shamir Secret Sharing a soglia 2-di-3, con guardiani che scegli tu.

Infrastruttura. Tu scegli i server. Lattice fornisce il software, le istruzioni di setup, e — opzionalmente — il supporto operativo. Non fornisce hosting. Questa è una scelta consapevole: il momento in cui Lattice gestisse anche l'hosting, la sovranità dell'infrastruttura passerebbe in larga misura nelle nostre mani, e saremmo noi a essere un nuovo "fornitore unico" come quelli che critichiamo.

Aggiornamenti. Lattice rilascia aggiornamenti firmati con una chiave ML-DSA-65 pubblica, verificabile. Tu decidi quando installarli. Non c'è auto-update forzato. Esiste un canale "security advisories" per gli aggiornamenti critici, ma anche questi devono essere applicati da te.

Catena di fornitura. Lattice è scritto in Rust (per le componenti crittografiche) e Python (per il backend FastAPI). Le librerie crittografiche utilizzate sono quelle di riferimento del NIST (PQClean, libsodium, ring), tutte open source ispezionabili. La build è riproducibile su qualunque macchina Linux/macOS. Il binario di rilascio ha un hash SHA-256 pubblicato e firmato.

4.3 — Sovranità di concetto vs sovranità di marketing

Ci sono fornitori — anche italiani — che si presentano come "sovrani" ma soddisfano solo una o due delle sei dimensioni. Vale la pena dare alcuni esempi anonimi per allenare l'occhio.

Esempio 1. Provider PEC italiano che ospita su Azure (datacenter in Irlanda). Sovranità dei dati: ridotta (Microsoft può tecnicamente accedere). Sovranità dell'infrastruttura: zero (l'hosting è di

Microsoft). Sovranità delle chiavi: zero (le chiavi sono del provider, non del cliente). Marketing: "PEC italiana sovrana".

Esempio 2. Cloud "sovrano europeo" che è in realtà una rivendita di Google Cloud con una clausola contrattuale sulle giurisdizioni. Sovranità del codice: zero. Sovranità dell'infrastruttura: nominale. Sovranità delle chiavi: gestita dal provider. Marketing: "cloud sovrano".

Esempio 3. Piattaforma di messaggistica "made in Italy" che usa server Microsoft Azure West Europe, codice chiuso, chiavi gestite dal provider. Soddisfa la dimensione "dati nominalmente in Europa", nient'altro. Marketing: "messaggistica sovrana italiana".

Il punto non è demonizzare questi prodotti. Il punto è capire che "sovrano" senza specificazione tecnica non vuol dire niente. La sei-dimensioni è uno strumento di valutazione che un CISO può applicare in fase di RFP per separare le proposte serie da quelle puramente di marketing.

4.4 — La sovranità non è solo per le aziende paranoiche

C'è un'obiezione tipica al ragionamento sulla sovranità: "Ma sono cose da governi, da intelligence, da settori critici. La mia azienda media non ne ha bisogno". Vale la pena rispondere brevemente.

Primo: la sovranità è cumulativa. Più cose dipendono dallo stesso fornitore, più una sua compromissione propaga danno. Un'azienda media che ha mail su Microsoft, chat su Microsoft Teams, archivio su OneDrive, autenticazione su Azure AD e backup

su Microsoft Azure ha — in pratica — un unico point of failure per l'intera capacità di operare. La sua "non paranoia" è un'esposizione strutturale.

Secondo: i regolatori, in Europa e in Italia, stanno spostando l'attenzione verso il requisito di sovranità anche per le aziende ordinarie. NIS2 richiede misure di resilienza che, di fatto, presuppongono alternative di emergenza al fornitore primario. DORA impone, per il settore finanziario, una mappatura completa delle dipendenze ICT con piano di sostituzione. eIDAS 2.0 spinge verso identità digitali europee non controllate da fornitori americani.

Terzo: il differenziale di costo tra una soluzione "ovunque sia il fornitore" e una soluzione sovrana si è ridotto drasticamente. Lattice, on-premise, ha un costo total cost of ownership confrontabile a quello di Microsoft 365 per aziende medie, ed è significativamente più basso per aziende sopra i 200 dipendenti.

Per chi vuole approfondire il calcolo TCO, c'è il capitolo 13. Per ora, prendete questo: la sovranità non è più un costo aggiuntivo da CISO paranoici, è una condizione di operatività normale per il 2026.

4.5 — Domanda per la prossima riunione

Portate questa domanda al prossimo CdA: **"Su quante delle sei dimensioni — codice, dati, chiavi, infrastruttura, aggiornamenti, catena di fornitura — abbiamo controllo effettivo per la nostra infrastruttura di comunicazione?"**

Se la risposta è "zero o una", siete dipendenti totali. Se è "due o tre", siete dipendenti con qualche margine di manovra. Se è

"quattro o più", complimenti — siete tra le poche aziende italiane veramente sovrane.

CAPITOLO 5 — Cloud pubblico, SaaS estero e il mito del "private link".

5.0 — Apertura

La risposta più frequente che un fornitore di cloud pubblico (Microsoft, Google, AWS) dà a un CISO italiano preoccupato della sovranità è: "Abbiamo il private link / il datacenter europeo / la sovereignty option / il sovereign cloud announcement". È una risposta sofisticata e ben preparata, perché copre la domanda formale senza affrontare la sostanza tecnica.

In questo capitolo demoliamo, una alla volta, le quattro promesse standard che i grandi fornitori cloud fanno per sembrare "sovrani". Lo facciamo senza animosità: questi fornitori sono ottimi per ciò che fanno bene (scalare globalmente, offrire migliaia di servizi managed). Il punto è capire che non possono essere sovrani — è strutturalmente impossibile.

5.1 — Promessa 1 — "I dati sono in Europa"

Microsoft, Google, AWS hanno tutti datacenter in Irlanda, Olanda, Germania, Francia, Italia. Tecnicamente è vero che i dati possono essere localizzati nei datacenter europei.

Ma la localizzazione fisica del dato è solo uno dei sei requisiti di sovranità (capitolo 4). Restano fuori: sovranità del codice (il

fornitore non ti mostra il sorgente), sovranità delle chiavi (Microsoft conserva le chiavi master, anche se tu hai una "customer-managed key" — c'è sempre una chiave di emergenza del fornitore), sovranità dell'infrastruttura (i server, gli ipervisori, le reti sono di Microsoft), sovranità degli aggiornamenti (Microsoft aggiorna quando vuole), sovranità della catena di fornitura (Microsoft compila e firma il software).

Più importante ancora: il **CLOUD Act statunitense** del 2018 impone a Microsoft, Google e AWS di consegnare i dati alle autorità americane su richiesta motivata, anche se i dati sono fisicamente in Europa. Non è una clausola contrattuale aggirabile: è una legge federale che obbliga questi fornitori. La sentenza Schrems II della Corte di Giustizia UE (2020) ha dichiarato questo regime incompatibile con il GDPR, ma sei anni dopo l'industria continua a usare gli stessi servizi.

Conclusione: "dati in Europa" è una metà dell'opera. Risolve la conformità GDPR formale (a fatica), non la sovranità sostanziale.

5.2 — Promessa 2 — "Private link / network isolation"

I private link (Azure Private Link, AWS PrivateLink, Google Private Service Connect) sono connessioni dedicate tra il datacenter del cliente e i servizi cloud, che evitano il transito su Internet pubblica. Sono utili per la sicurezza in transito, ma non per la sovranità.

Una volta che i dati arrivano nel datacenter del fornitore, sono nel suo ambiente. Il private link non cambia chi vede i dati a

destinazione. Non cambia chi può sospendere il servizio. Non cambia chi possiede le chiavi.

Conclusione: il private link risolve un problema specifico (intercettazione del traffico Internet pubblica), non il problema della sovranità.

5.3 — Promessa 3 — "Customer-managed encryption keys"

Microsoft Azure Key Vault, AWS KMS e Google KMS offrono opzioni di "customer-managed keys" (CMK), dove il cliente può portare la propria chiave master invece di usare quella del fornitore.

In linea di principio è una bella idea. In pratica c'è un dettaglio nascosto: la chiave del cliente è comunque protetta da una chiave del fornitore (root-of-trust). Il fornitore non vede mai la chiave del cliente in chiaro, ma ha la capacità tecnica, in casi di emergenza dichiarati, di accedere alle chiavi della propria infrastruttura. Microsoft lo documenta esplicitamente come "Microsoft Recovery Key" nei propri whitepaper compliance.

Inoltre, anche se la chiave del cliente fosse perfettamente protetta, il fornitore può sempre sospendere il servizio (negazione del servizio anche se i dati sono cifrati con chiave del cliente). E può sempre ricevere un ordine giudiziario che richiede la consegna dei dati cifrati al cliente, lasciando al cliente l'onere di rifiutare di decifrarli (con costi legali notevoli).

Conclusione: la CMK è meglio delle chiavi del fornitore, ma non è equivalente a chiavi sotto il controllo esclusivo del cliente.

5.4 — Promessa 4 — "Sovereign cloud" recente (2024-2026)

Microsoft ha lanciato nel 2024 il "Microsoft Cloud for Sovereignty", Google ha annunciato un "Sovereign Controls" e AWS un "European Sovereign Cloud" previsto per il 2026. Sono offerte costruite specificamente per rispondere alla pressione regolatoria europea.

Da quello che è pubblicamente documentato, queste offerte garantiscono: (a) datacenter in Europa con personale solo europeo, (b) niente accesso da parte di personale del fornitore di paesi terzi senza approvazione del cliente, (c) procedure rinforzate di risposta a richieste extraterritoriali.

Sono passi avanti reali. Ma rimangono tre limiti strutturali: (i) il codice resta proprietario e non auditabile dal cliente, (ii) le chiavi crittografiche di root sono comunque sotto controllo del fornitore (anche se geograficamente isolate), (iii) il fornitore può ancora sospendere il servizio o uscire dal mercato europeo per decisione corporate.

Conclusione: il "sovereign cloud" è un miglioramento marginale del rischio, non una sovranità tecnica. Per dati realmente strategici (M&A, segreti industriali, comunicazioni legali, contenziosi) resta inadeguato.

5.5 — Cosa significa, in pratica, "sovrano davvero"

Ricapitolando dal capitolo 4: una piattaforma "sovrana davvero" deve essere:

16. Open source (almeno per le componenti crittografiche e di sicurezza) o, in alternativa, soggetta a escrow del codice presso un terzo affidabile.
17. Hostable on-premise o in un'infrastruttura europea che il cliente sceglie e audita (non in cui il cliente "è ospitato").
18. Con chiavi generate e conservate dal cliente, senza alcuna chiave di recovery del fornitore.
19. Aggiornabile su decisione del cliente (no auto-update forzato).
20. Buildabile in modo riproducibile.

Lattice è progettato per soddisfare tutti e cinque i criteri. Il prezzo è che richiede al cliente di gestire la propria infrastruttura (server fisici o cloud sovrano selezionato da lui). Non offriamo "Lattice as a Service" gestito da noi, perché — coerentemente con il nostro discorso — questo creerebbe un nuovo fornitore-monopolista. Offriamo il software e il know-how per metterlo in opera.

5.6 — Quando il cloud pubblico va benissimo

Per essere onesti: il cloud pubblico non è il diavolo. Per molte aziende e per molti servizi è la scelta giusta. Il punto del capitolo è che **non lo è per la comunicazione aziendale ad alto valore strategico o probatorio**.

Il cloud pubblico va benissimo per: ospitare il sito web aziendale, il CRM (per quanto: vedi anche qui), il CMS, le applicazioni interne

non sensibili, gli ambienti di sviluppo e test, i workload massivi di calcolo (HPC, AI training), lo storage di dati pubblici o anonimizzati.

Il cloud pubblico va male per: la mail con valore legale, la chat interna con segreti industriali, l'archivio dei contratti firmati, le comunicazioni del consiglio di amministrazione, i contenziosi in corso, le pratiche M&A, i piani strategici di prodotto. Per queste cose, Lattice è la risposta razionale del 2026.

5.7 — Domanda per la prossima riunione

Portate questa domanda al CdA: **"Per quale singola informazione strategica della nostra azienda — segreto industriale, lista clienti chiave, trattativa in corso — saremmo davvero a nostro agio se Microsoft o Google la leggesse?"**

Se la risposta è "nessuna", allora avete identificato esattamente ciò che deve uscire dal cloud pubblico. Lattice serve a quello.

CAPITOLO 6 — Self-hosting e on-premise come scelta strategica.

6.0 — Apertura

Negli anni 2010 il consenso del settore IT era: "il cloud è meglio per tutto". Il self-hosting era diventato sinonimo di arretratezza tecnologica. Server fisici in azienda, amministrati da un team interno, erano percepiti come una soluzione del passato.

Quel consenso è cambiato a partire dal 2022. La combinazione di crescita dei costi cloud, normativa europea sulla data sovereignty (GDPR + NIS2 + DORA + AI Act), sospensioni di account da parte di hyperscaler e maturità degli strumenti open-source ha riportato il self-hosting al centro del dibattito IT — non come scelta nostalgica, ma come scelta strategica per workload specifici.

Questo capitolo ragiona sul perché il self-hosting (o, in alternativa, l'hosting in cloud sovrano europeo selezionato dal cliente) è la scelta giusta per la comunicazione aziendale ad alto valore, e sui contro-argomenti che vengono tipicamente sollevati.

6.1 — Cosa intendiamo per "self-hosting"

Per chiarezza, distinguiamo due modelli:

Self-hosting puro (on-premise). I server fisici sono nel datacenter dell'azienda o in un suo locale dedicato. L'azienda li acquista, li

amministra, li sostituisce. La connettività e l'alimentazione sono garantite dall'azienda.

Hosting in cloud sovrano selezionato (private cloud). I server fisici sono in un datacenter di un fornitore europeo scelto dall'azienda (OVH, Hetzner, Aruba, Seeweb, Scaleway, IRIDEOS, partner regionali). L'azienda non possiede l'hardware, ma sceglie il fornitore, audita il contratto, e ha facoltà di portabilità completa.

Per il discorso di questo libro entrambi i modelli sono accettabili, perché entrambi soddisfano le sei dimensioni della sovranità del capitolo 4. Il primo (on-premise) ha sovranità leggermente più forte; il secondo (cloud sovrano selezionato) ha costi operativi inferiori. Per la maggior parte delle PMI italiane, il cloud sovrano selezionato è il punto di equilibrio ragionevole.

6.2 — I cinque vantaggi del self-hosting per la comunicazione

Vantaggio 1 — Continuità. Nessun fornitore può sospendere il servizio. L'unica autorità che può imporre uno spegnimento è la magistratura italiana o europea, con procedimento documentato. Il rischio di sospensione "amministrativa" o "automatica" è eliminato.

Vantaggio 2 — Riservatezza tecnica. I dati sono fisicamente nei server della tua azienda (o del cloud sovrano che tu hai scelto). Nessun fornitore extra-UE ha accesso tecnico. Le richieste di consegna di dati da parte di autorità estere non sono soddisfacibili perché Lattice come azienda non ha accesso ai dati dei clienti.

Vantaggio 3 — Costo prevedibile. I costi del cloud pubblico crescono in modo non sempre lineare al business (storage,

bandwidth, computation, API calls). Il self-hosting ha costi fissi (hardware, manutenzione, energia, banda) che possono essere previsti con accuratezza per 3-5 anni. Per aziende sopra i 200 dipendenti, il TCO del self-hosting per la sola comunicazione è inferiore a quello di Microsoft 365 nell'80% dei casi che abbiamo analizzato.

Vantaggio 4 — Audit indipendente. Tu puoi auditare l'infrastruttura, il codice, le configurazioni. Puoi pubblicare il risultato dell'audit (come fanno alcune banche) per rafforzare la fiducia dei clienti. Il fornitore cloud non ti offre questa trasparenza, perché il suo modello di business è proprio la non-ispezione.

Vantaggio 5 — Personalizzazione. Lattice si integra con i tuoi sistemi esistenti (Active Directory, gestionale, ERP) in modo nativo. Le policy di archiviazione, retention, classificazione le decidi tu. Nessun "click-through agreement" con un fornitore esterno.

6.3 — I quattro contro-argomenti tipici (e perché non reggono più)

Contro-argomento 1 — "Non abbiamo competenze interne". Era vero quando l'on-premise voleva dire installare e amministrare un server Exchange con migliaia di parametri. Oggi Lattice (e piattaforme moderne in generale) si installa via container Docker o appliance virtuale. Il setup iniziale richiede una settimana di un partner di Lattice. La manutenzione ordinaria richiede meno di 4 ore al mese di un sysadmin senior. Per un'azienda sopra i 50 dipendenti il costo equivalente di un consulente esterno

specializzato è inferiore al costo della licenza Microsoft 365 Business Premium per gli stessi utenti.

Contro-argomento 2 — "Non possiamo permetterci l'hardware". L'hardware necessario per ospitare Lattice per un'azienda di 50-200 dipendenti è modesto: 2 server fisici (per ridondanza) con 32 GB di RAM, 1 TB di storage NVMe ciascuno. Costo totale: tra i 4.000 e gli 8.000 euro una tantum, ammortizzati su 5 anni. Per 1.000 dipendenti, l'investimento sale a 30.000-50.000 euro. Confrontato con il costo annuale di Microsoft 365 per quel numero di utenti (oltre 100.000 euro/anno), l'hardware si ammortizza in pochi mesi.

Contro-argomento 3 — "Non abbiamo continuità operativa H24". I provider di cloud pubblico hanno SLA del 99.9% (~8 ore di downtime all'anno) o 99.95%. Lattice, configurato con ridondanza standard, raggiunge SLA del 99.95% con architettura interna o del 99.99% con cloud sovrano di seconda generazione. La differenza in pratica è negligibile, e l'overhead di gestione è meno di quello che si pensa.

Contro-argomento 4 — "Il cloud è il futuro, non vogliamo andare contro tendenza". Il cloud per scalabilità globale è il futuro. Il cloud per dati strategici aziendali sta perdendo terreno in tutta Europa proprio mentre scriviamo. Banche tedesche, francesi e olandesi stanno tornando a infrastrutture sovrane per le comunicazioni regolamentate. Le linee guida BSI, ANSSI, ENISA del 2024-2025 spingono verso la sovranità tecnica reale. L'Italia, in ritardo come al solito sulle tendenze regolatorie, arriverà su queste posizioni entro il 2027.

6.4 — Quando Lattice gira nel cloud sovrano

Per le aziende che non vogliono gestire hardware fisico, Lattice è installabile nei seguenti provider di cloud sovrano europeo che abbiamo testato e con cui abbiamo partnership documentate:

- **OVHcloud** (Francia, Italia, Germania) — Bare metal o cloud pubblico, ISO 27001 + SecNumCloud (qualificazione ANSSI).
- **Hetzner** (Germania) — Bare metal economico, datacenter in DE/FI.
- **Aruba** (Italia) — Datacenter italiani, certificazione ACN per PA.
- **Seeweb** (Italia, gruppo Hosting Solutions) — Italia, ISO 27001/27017/27018.
- **Scaleway** (Francia, gruppo Iliad) — Datacenter europei, focus sviluppatori.

Tutti i provider citati hanno clausole contrattuali standard che escludono il trasferimento dati extra-UE e che garantiscono la portabilità (export completo, niente lock-in di formato). Le configurazioni reference che pubblichiamo sono testate su questi cinque provider.

Importante: Lattice **non** raccomanda — e tecnicamente non supporta — il deployment su Azure, AWS, Google Cloud o altri hyperscaler americani, anche nelle loro "regioni sovrane". Sarebbe contraddire la promessa del prodotto.

6.5 — La transizione concreta

Migrare a Lattice non significa "spegnere Microsoft 365 lunedì". Significa pianificare una transizione progressiva, tipicamente in tre fasi.

Fase 1 — Comunicazioni ad alto valore (3-6 mesi). Si migra a Lattice ciò che ha più valore strategico o probatorio: comunicazioni del consiglio, M&A, contenziosi in corso, brevetti, segreti industriali. Il resto rimane su Microsoft 365.

Fase 2 — Comunicazioni operative medie (6-12 mesi). Si migra la corrispondenza con clienti chiave, la chat di reparto, le decisioni operative dei comitati. Microsoft 365 viene confinato a comunicazioni "leggere" o esterne non strategiche.

Fase 3 — Cleanup finale (12-24 mesi). Tipicamente, la maggior parte delle aziende che ha completato la fase 2 sceglie di lasciare Microsoft 365 solo come "mail marketing / mail leggera / collegamenti col mondo extra". Il volume effettivo passa per il 70-90% su Lattice. Il costo della licenza Microsoft scala di conseguenza (passa da Business Premium a Exchange Online Plan 1 per i restanti utenti).

Questo modello "ibrido controllato" è quello che la maggior parte dei clienti enterprise di Lattice adotta. È pragmatico, ha rischi gestibili, e produce ROI misurabile sin dalla fase 1.

6.6 — Domanda per la prossima riunione

Portate questa domanda al CdA: **"Quale percentuale del nostro fatturato dipende, oggi, da una mail o da una chat che gira su infrastruttura non controllata da noi? E in fase 1 di una migrazione,**

qual è il primo 10% di comunicazione che vorremmo mettere al sicuro?"

Se ne discutete in modo concreto, vi accorgerete che la migrazione non è un salto nel vuoto. È una scelta razionale di quale rischio è prioritario.

CAPITOLO 7 — L'architettura di Lattice Network.

7.0 — Apertura

Dopo sei capitoli che hanno raccontato perché esiste un problema e come Lattice lo affronta a livello di business, questo è il primo capitolo che entra nei dettagli tecnici. È pensato per chi vuole capire come funziona davvero la macchina sotto il cofano: CTO, CISO, architetti di sicurezza, sviluppatori, consulenti tecnici. Il lettore non-tecnico può saltare al capitolo 12 senza perdere il filo del discorso.

7.1 — La domanda di partenza

Costruire un'infrastruttura di comunicazione aziendale sovrana richiede di soddisfare cinque vincoli simultaneamente, che storicamente sono stati visti come trade-off:

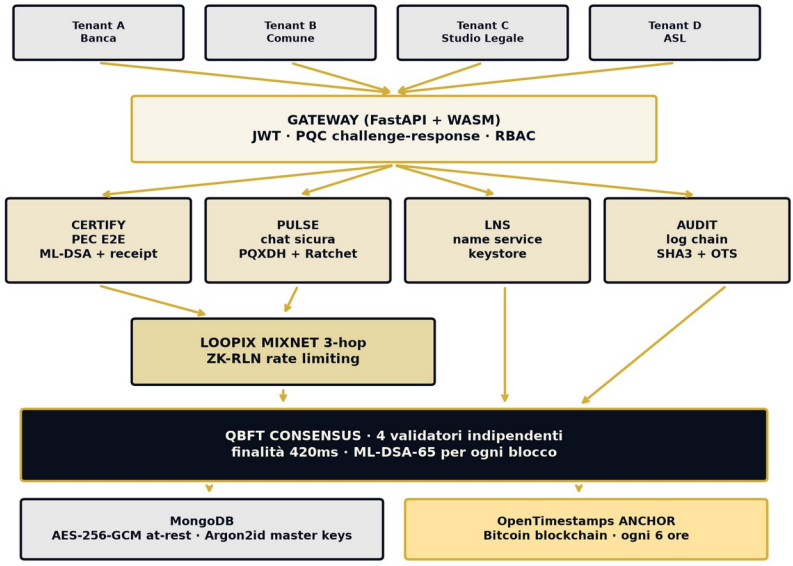
21. **Riservatezza forte** — i contenuti devono restare cifrati end-to-end, leggibili solo dal mittente e dal destinatario.
22. **Identità aziendale verificabile** — chi scrive deve essere riconoscibile in modo crittografico come membro della stessa azienda.
23. **Prova legale opponibile** — ogni mail "ufficiale" deve essere notarizzata in modo verificabile pubblicamente.

24. **Resistenza al futuro** — la crittografia deve essere immune ai computer quantistici (NIST FIPS 203/204).
25. **Operabilità su rete privata** — l'intera infrastruttura deve poter girare offline, on-premise, senza dipendere da servizi esterni.

L'architettura di Lattice è il risultato della scelta di non sacrificare nessuno di questi cinque vincoli. È una scelta che ha aumentato la complessità implementativa, ma che — secondo gli autori — è l'unica onesta dato il problema da risolvere.

7.2 — Vista d'insieme

Fig. 7.1 — Architettura Lattice Network



Lattice Network — 5 colonne · 7 layer di difesa in profondità

Lattice è organizzato in cinque layer logici, ciascuno con responsabilità definite:

Layer 1 — Storage layer. Database MongoDB (o equivalente compatibile) con cifratura at-rest AES-256-GCM. Conserva: identità LNS, transazioni del ledger, blocchi finalizzati, mail Certify cifrate, conversazioni Pulse cifrate, audit log.

Layer 2 — Crypto layer. Componente Rust (compilato in WebAssembly per il browser e in nativo per il backend) che implementa: ML-DSA-65 (firma post-quantum), ML-KEM-768 (key encapsulation post-quantum), SHA3-512 (hash), AES-256-GCM (cifratura simmetrica), Argon2id (key derivation), Shamir Secret Sharing su GF(256) (key recovery).

Layer 3 — Ledger layer. Implementazione tokenless del consenso QBFT (Quorum Byzantine Fault Tolerant), con finalità deterministica entro 1-3 secondi e tolleranza a f<n/3 nodi guasti o malevoli. I blocchi seguono il modello Substrate (extrinsics_root, state_root, weight_used, events). Tutte le transazioni sono firmate ML-DSA-65.

Layer 4 — Application layer. FastAPI (Python) come backend HTTP, organizzato in moduli: `lns` (identità), `certify` (mail), `pulse` (chat), `keyrecovery` (recupero chiavi), `explorer` (verifica pubblica), `qbft` (consenso), `tenants` (multi-tenancy).

Layer 5 — Presentation layer. Single Page Application React + TailwindCSS. Comunica col backend via REST + Server-Sent Events. Tutta la crittografia sensibile (generazione chiavi, firma, decifratura messaggi) avviene client-side via WASM. Il backend non vede mai chiavi segrete utente.

7.3 — Il principio dell'isolamento multi-tenant

Lattice è progettato per supportare **più aziende sulla stessa rete fisica senza che possano vedersi a vicenda**. Questa proprietà — l'isolamento multi-tenant — è critica per due ragioni: (a) permette a Lattice come operatore di rete di servire più clienti su un'infrastruttura condivisa quando appropriato, (b) ma soprattutto, dentro una singola azienda, isola i tenant logici (es. controllata vs capogruppo, azienda vs partner esterno).

L'isolamento è implementato a quattro livelli:

Isolamento crittografico. Ogni tenant ha la propria chiave di gateway (`CERTIFY-GATEWAY-{tenant_id}`). Le mail e i messaggi di un tenant sono cifrati con chiavi diverse da quelli di un altro tenant. Anche se l'infrastruttura fisica è condivisa, un tenant non può leggere i dati di un altro perché non possiede le chiavi.

Isolamento di identità. Le identità LNS sono organizzate per tenant in modo gerarchico (`mario.acme.lns` vs `paolo.beta.lns`). L'API di Lattice rifiuta richieste cross-tenant a meno che il sovrano-operatore non abbia esplicitamente abilitato un trust link.

Isolamento di accesso. I JWT di autenticazione contengono il tenant_id e la role. L'API verifica entrambi prima di restituire qualunque dato. Un utente di acme non può accedere a un endpoint che gli restituirebbe dati di beta, anche manipolando l'URL.

Isolamento di audit. Ogni transazione on-chain contiene il tenant_id come metadato. L'Audit Pubblico mostra dati aggregati per tenant senza esporre cross-correlazioni indebite.

7.4 — Il flusso di una mail Certify, passo passo

Per rendere concreta l'architettura, vediamo cosa succede quando Mario di Acme invia una mail Certify a Paolo di Beta.

26. **Composizione (browser di Mario).** Mario scrive la mail. Il client React tiene il contenuto in memoria locale.
27. **Recupero chiave destinatario.** Il client di Mario chiede al backend la chiave pubblica ML-KEM-768 di Paolo. Il backend la restituisce insieme alla prova di registrazione on-chain.
28. **Cifratura (browser di Mario).** Il client genera una chiave simmetrica AES-256 effimera, cifra il contenuto, e poi incapsula la chiave AES con la chiave pubblica ML-KEM-768 di Paolo. Solo Paolo, con la sua chiave segreta, potrà decifrare.
29. **Hash e firma (browser di Mario).** Il client calcola SHA3-512 dell'header (mittente, destinatario, oggetto, timestamp, hash_contenuto_cifrato). Firma l'header con la chiave segreta ML-DSA-65 di Mario.
30. **Invio al backend (rete cifrata TLS).** Il client invia: header firmato, contenuto cifrato, firma di Mario. La chiave segreta di Mario non lascia mai il browser.
31. **Verifica del backend.** Il backend verifica la firma di Mario (usando la chiave pubblica registrata on-chain di Mario). Se valida, costruisce una transazione `NotarySeal` che contiene header firmato e hash. Firma a sua volta la transazione con la chiave di gateway di Acme.
32. **Finalizzazione QBFT.** La transazione viene inviata ai validatori QBFT. Quando ricevono 2/3 + 1 dei voti, viene finalizzata in un nuovo blocco entro 1-3 secondi.
33. **Notifica e consegna.** Il backend di Lattice notifica via SSE il client di Paolo. Paolo apre la mail; il suo client decapsula la

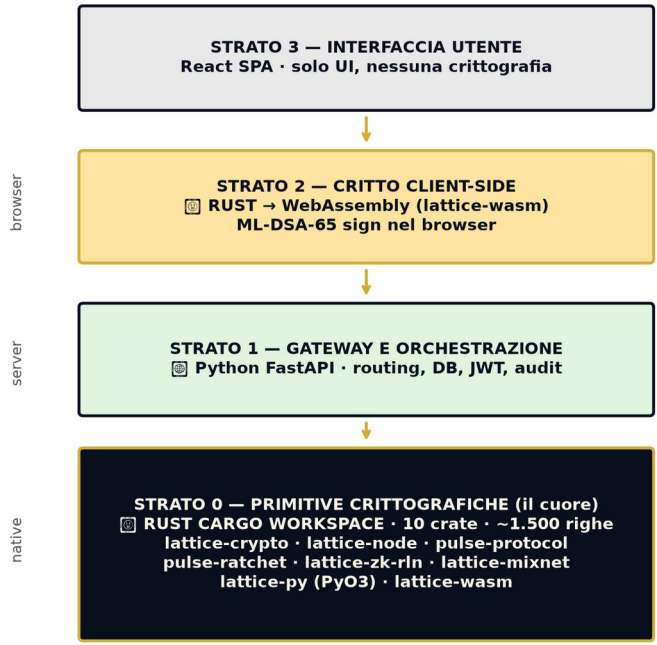
chiave AES con la sua chiave segreta, decifra il contenuto e firma una `DeliveryReceipt` che testimonia l'apertura.

34. **Notarizzazione della ricevuta.** La DeliveryReceipt viene anch'essa firmata, inviata, validata QBFT e finalizzata.

Risultato: Mario ha una prova crittografica che (a) la mail è stata inviata da lui, (b) è arrivata a Paolo, (c) è stata effettivamente aperta. Tutto verificabile pubblicamente sul Block Explorer.

7.5 — Lo stack tecnico in pratica

Fig. 7.2 — Architettura ibrida Rust + Python + WASM



Per i lettori tecnici, ecco lo stack in dettaglio:

Componenti Rust (crittografia e core):

- `pqcrypto-dilithium` per ML-DSA-65 (NIST FIPS 204).
- `pqcrypto-kyber` per ML-KEM-768 (NIST FIPS 203).
- `sha3` per SHA3-512.
- `aes-gcm` per AES-256-GCM.
- `argon2` per Argon2id.
- `gf256` (sviluppato internamente) per Shamir Secret Sharing.

Compilato in WebAssembly via `wasm-bindgen` per uso nel browser. Compilato in libreria nativa per uso nel backend Python via `PyO3`.

Backend Python:

- FastAPI + Uvicorn (async server).
- Motor (driver MongoDB async).
- PyJWT per i token di sessione.
- `python-multipart` per upload allegati.

Frontend React:

- React 19 + Vite.
- TailwindCSS + shadcn/ui.
- Axios per HTTP, EventSource per SSE.
- WebAssembly bindings via `lattice-wasm.js`.

Storage:

- MongoDB 7+ (o compatibile come Percona Server for MongoDB).
- Cifratura at-rest a livello di filesystem (LUKS su Linux) o nativa MongoDB Enterprise.

7.6 — Le decisioni controverse

Vale la pena spiegare alcune scelte architetturali che sono state oggetto di dibattito interno e che continuano a sollevare domande dai clienti tecnici.

Perché tokenless. Lattice non ha una criptovaluta nativa. Le transazioni non hanno gas fees. Questa scelta deriva dall'osservazione che le reti tokenizzate hanno introdotto, nelle blockchain pubbliche, un meccanismo economico necessario per allineare incentivi tra nodi anonimi. In una rete aziendale dove i validatori sono identificati e contrattuali, il token è una complicazione inutile. Tokenless = nessuna esposizione finanziaria, nessuna pressione regolatoria su asset crypto, focus sul valore probatorio.

Perché QBFT e non PoS. QBFT (Quorum Byzantine Fault Tolerant) raggiunge finalità deterministica entro pochi secondi con un numero limitato di validatori (tipicamente 4-21). Proof-of-Stake richiederebbe un sistema di staking economico che — di nuovo — è inutile in una rete identificata. QBFT è la scelta giusta per blockchain "permissionata", che è la categoria di Lattice.

Perché ML-DSA-65 e non SLH-DSA. Sono entrambi standard NIST post-quantum (FIPS 204 e FIPS 205). ML-DSA-65 ha firme di 3.293 byte, SLH-DSA-Sha2-256s ha firme di 29.792 byte. Per un sistema che firma milioni di transazioni, la dimensione di firma è il vincolo critico. ML-DSA-65 vince per economia di banda e storage senza compromettere la sicurezza.

Perché Rust per la crittografia. Sicurezza di memoria garantita a compile-time, performance native, audit open-source disponibili

sulle principali librerie post-quantum. Le alternative (Go, C++, Python wrappers) hanno tutte limiti documentati.

7.7 — Domanda per il proprio CTO

Se siete un CISO o un dirigente non-tecnico, portate questa domanda al vostro CTO o consulente di sicurezza: **"L'architettura di Lattice, come descritta nel capitolo 7 e nei whitepaper pubblici, soddisfa i nostri requisiti di sicurezza, prestazioni e operabilità? Quali sono le tre cose che ti preoccupano di più?"**

Le risposte del CTO sono il punto di partenza concreto della valutazione. Lattice è disegnato per superare gli scrutini tecnici seri — non per evitarli.

CAPITOLO 7B — Block Explorer pubblico e Gateway Delegation.

Due caratteristiche tecniche specifiche di Lattice che valgono un capitolo a parte, perché toccano due domande operative ricorrenti: "come dimostro a un terzo che la mail esiste davvero?" e "come fa un dipendente a firmare on-chain senza che il backend tenga la sua chiave?".

7B.1 — Il Block Explorer pubblico: la prova senza fornitore

Una delle proprietà più importanti di Lattice, e una di quelle che la differenzia in modo netto dalle alternative SaaS, è che **chiunque, in qualsiasi momento, può verificare la validità di una transazione, di un blocco o dell'hash di un documento, senza dover passare attraverso il fornitore.**

Questa proprietà si materializza in uno strumento concreto chiamato **Block Explorer**. È un'applicazione web pubblica, accessibile da qualsiasi browser senza autenticazione, che mostra in tempo reale lo stato del ledger interno di Lattice: i blocchi finalizzati, le transazioni registrate, le identità (LNS) attive e revocate, le notarizzazioni di mail e documenti.

A cosa serve, in pratica

Immagina questo scenario. La tua azienda, due anni fa, ha inviato un'offerta vincolante a un cliente via Lattice Certify. Il cliente, oggi, contesta il contenuto dell'offerta sostenendo che è stata "modificata dopo l'invio". Nella prassi italiana, questo significherebbe attivare un consulente tecnico d'ufficio che verifichi gli archivi del provider di posta. Se il provider non esiste più, o ha cambiato formato, o richiede tempi lunghi, la verifica diventa difficile.

Con Lattice, il procedimento è molto più diretto. Tu (o il giudice, o l'avvocato della controparte, o il consulente tecnico) apri il Block Explorer pubblico di Lattice, cerchi l'identificativo della mail (un hash SHA3-512 di 128 caratteri esadecimali) e ottieni una pagina con queste informazioni:

- **Hash del documento**: l'impronta crittografica del contenuto originale. Se ricalcoli l'hash della mail che tieni in archivio e ottieni lo stesso valore, hai dimostrato matematicamente che il contenuto non è stato modificato.
- **Firma digitale del mittente**: la firma ML-DSA-65 (post-quantum) applicata dalla chiave segreta del mittente al momento dell'invio. Se la verifica passa, hai dimostrato che il mittente è davvero la persona che dici.
- **Blocco e timestamp di notarizzazione**: il numero del blocco in cui la transazione è stata finalizzata, e il momento esatto (al secondo) in cui questo è avvenuto. Questo timestamp è opponibile in giudizio come ora certa, perché è stato concordato dai validatori QBFT che hanno firmato quel blocco — nessun singolo soggetto può alterarlo retroattivamente.

- **Ancoraggio esterno (opzionale)**: se la transazione è stata anche ancorata su Bitcoin tramite OpenTimestamps (vedi sezione 7B.3), il riferimento alla transazione Bitcoin è qui. Significa che la prova non dipende più nemmeno dalla rete Lattice: dipende dalla rete Bitcoin, che è una rete pubblica globale gestita da decine di migliaia di nodi indipendenti.

Tutto questo è verificabile **senza chiamare nessuno**. Senza dover credere a Lattice. Senza dover credere al provider PEC. La verifica è autonoma e crittografica.

Cosa è pubblicamente visibile e cosa no

Una preoccupazione legittima dei clienti aziendali, in fase di valutazione, è: "Ma allora chiunque può leggere le mie mail nel Block Explorer?". **No, e questa è una distinzione critica.**

Il Block Explorer mostra solo l'**hash crittografico** del documento — un numero di 128 caratteri esadecimali che funge da "impronta" — non il contenuto. L'hash è una funzione unidirezionale: a partire dall'hash, è impossibile ricostruire il contenuto originale. Quello che la chain conserva è:

- L'hash del documento (impronta) — pubblico.
- L'identità del mittente in formato LNS (es. `mario.rossi.acme.lns`) — pubblico.
- L'identità del destinatario in formato LNS — pubblico.
- Il timestamp di notarizzazione — pubblico.
- La firma digitale — pubblica.

- **Il contenuto della mail e degli allegati — privato**, conservato cifrato sui server di Lattice della tua azienda, accessibile solo a mittente e destinatario.

Questo modello — *publish the proof, hide the payload* — è lo stesso adottato da OpenTimestamps su Bitcoin, da DocuSign per le firme digitali, da Certificate Transparency per i certificati TLS. È un modello consolidato.

Per i clienti che richiedono un livello superiore di riservatezza (es. studi legali con clientela ad alto profilo), Lattice offre un'opzione di **anonimizzazione delle identità on-chain**: invece di pubblicare `mario.rossi.acme.lns`, pubblica un hash dell'LNS che è verificabile solo da chi conosce la chiave. La proprietà di non-ripudio è preservata, ma la corrispondenza mittente-destinatario non è leggibile pubblicamente.

Per il pubblico esterno: l'audit pubblico aziende

Oltre al Block Explorer di basso livello (transazioni e blocchi), Lattice offre un'interfaccia di livello superiore chiamata **Audit Pubblico** che mostra, per ogni azienda registrata sulla rete, alcune metriche aggregate:

- Numero di identità attive.
- Numero di mail certificate negli ultimi 30 giorni.
- Numero di messaggi Pulse scambiati.
- Eventuali eventi di revoca (con motivazione anonimizzata).
- Indicatore di salute della rete (validatori online, ultima ancora Bitcoin, eccetera).

Questa interfaccia non rivela contenuti né identità individuali, ma fornisce a un eventuale ispettore, certificatore o controparte un'idea immediata dell'attività e della governance della rete. È particolarmente utile per le aziende regolamentate (banche, assicurazioni) che devono dimostrare ai propri auditor che le comunicazioni interne sono effettivamente tracciate.

7B.2 — Gateway Delegation: come firmano i dipendenti

Una sfida ricorrente nelle infrastrutture di firma digitale è: **come fa un dipendente che ha perso il laptop, o che è in mobilità, a firmare un documento on-chain senza che le sue chiavi private siano memorizzate sul server?**

La risposta della maggior parte delle soluzioni commerciali è: "Le chiavi sono sul server, in cifratura at-rest". Questa risposta sembra ragionevole ma è insoddisfacente. Se il server è compromesso, le chiavi sono compromesse. Se il fornitore è obbligato per legge a consegnare le chiavi (CLOUD Act, ordinanza giudiziale), le chiavi sono consegnate. Se il provider chiude, le chiavi spariscono.

Lattice adotta un'architettura diversa, chiamata **Gateway Delegation**, che mantiene una proprietà fondamentale: **la chiave segreta dei singoli dipendenti non lascia mai i loro dispositivi**. Il backend di Lattice non ha mai accesso alla chiave segreta di Mario Rossi, neppure in forma cifrata.

Come funziona

Ogni azienda registrata su Lattice possiede una propria chiave di gateway: `CERTIFY-GATEWAY-{tenant_id}`. Questa è una chiave ML-DSA-65 (post-quantum) emessa al momento dell'onboarding dell'azienda, conservata sul backend di Lattice e usata per firmare on-chain le transazioni che riguardano l'attività dei dipendenti.

Quando Mario Rossi vuole inviare una mail Certify, succede questo:

35. Mario compone la mail nel suo browser. Il contenuto resta nel suo browser.
36. Mario clicca "invia". Il browser calcola localmente l'hash SHA3-512 del contenuto.
37. Il browser firma l'hash con la chiave segreta di Mario (`mario.rossi.acme.lns.sk`). La firma dimostra che il contenuto proviene da Mario. **La chiave segreta non lascia il browser.**
38. Il browser invia al backend di Lattice: il contenuto cifrato, l'hash, la firma di Mario.
39. Il backend di Lattice verifica la firma di Mario (usando la chiave pubblica di Mario, che è registrata on-chain).
40. Se la verifica passa, il backend costruisce una transazione "NotarySeal" che contiene: hash del documento, identità di Mario, identità del destinatario, firma di Mario, timestamp.
41. Il backend firma questa transazione con la chiave di gateway dell'azienda di Mario (`CERTIFY-GATEWAY-acme.lns`).
42. La transazione viene inviata ai validatori QBFT che la finalizzano in un nuovo blocco.

Il risultato è una transazione che ha **due firme**:

- La firma di Mario, che prova "questo contenuto è di Mario".

- La firma del gateway aziendale, che prova "questa transazione è stata correttamente ricevuta e processata dall'infrastruttura aziendale, secondo le policy dell'azienda".

Perché è importante questa separazione

La separazione tra "firma del dipendente" e "firma del gateway" risolve diversi problemi insieme.

Per la sicurezza individuale. Il backend non ha mai la chiave segreta di Mario. Se il backend è compromesso, l'attaccante non può impersonare Mario. Può, al massimo, costruire transazioni non firmate da Mario — ma queste verrebbero rifiutate dai validatori perché la firma di Mario sarebbe assente o falsa.

Per il non-ripudio individuale. Mario non può dire "non sono stato io" perché c'è la sua firma, applicata dalla sua chiave segreta che non ha mai lasciato il suo browser. Diversamente da Microsoft 365 (dove il fornitore potrebbe, in linea di principio, generare una mail "da Mario" senza la sua partecipazione), qui il fornitore non ha questa capacità.

Per il controllo aziendale. Allo stesso tempo, l'azienda mantiene il controllo: se Mario viene compromesso (ad esempio, viene revocato dall'azienda), tutte le firme future con la sua chiave verranno rifiutate dal sistema — perché il gateway aziendale controlla, prima di apporre la propria firma, che la chiave del mittente sia ancora attiva nel registro LNS.

Per la mobilità. Mario può firmare da qualunque dispositivo a patto di avere la sua chiave segreta. La chiave segreta è in un file

`.keypair.json` che lui custodisce. Se la perde, c'è il **Key Recovery via Shamir Secret Sharing** (vedi capitolo 8).

Cosa succede se il dipendente perde la chiave

Se Mario perde il file `.keypair.json` (laptop rubato, telefono perso, distruzione accidentale), non può più firmare. **Nessuno può impersonarlo**, neppure l'azienda — questa è una proprietà voluta.

Per recuperare l'accesso, Mario passa attraverso un procedimento di **Shamir Secret Sharing**: al momento dell'enrolment, il founder dell'azienda di Mario ha nominato tre "guardiani" (tipicamente: il founder stesso, un dirigente di fiducia, un avvocato esterno). Quando Mario chiede il recupero, due dei tre guardiani devono cooperare per ricostruire la chiave. Il procedimento è tracciato on-chain (richiesta, contributo dei guardiani, finalizzazione) ed è verificabile pubblicamente nel Block Explorer.

Se Mario non perde la chiave ma viene compromesso (esce dall'azienda in conflitto, sospetto di esfiltrazione), il founder non lo "recupera" — lo **revoca**: emette una transazione `IdentityRevoke` che dichiara la chiave di Mario non più valida dal blocco N in avanti. Il gateway aziendale, da quel momento, rifiuta ogni transazione firmata con la chiave di Mario. Le firme passate restano valide e verificabili (Mario *aveva* il diritto di firmare al momento in cui l'ha fatto), ma le future no.

Questa distinzione tra "recupero" (chi ha perso la chiave) e "revoca" (chi ha tradito) è gestita esplicitamente da Lattice in due flussi separati nell'interfaccia utente. Non è un dettaglio cosmetico: legalmente è la differenza tra un evento accidentale (per cui esiste

un protocollo di recovery firmato) e un evento disciplinare (per cui esiste una decisione amministrativa firmata dal founder).

7B.3 — Ancoraggio Bitcoin (opzionale)

Per i clienti che richiedono un livello di durabilità superiore — tipicamente: studi legali con archivi che devono valere oltre la vita del fornitore, banche con archivi regolatori a 10+ anni, ricerca farmaceutica con brevetti — Lattice offre un'opzione di **ancoraggio Bitcoin** tramite il protocollo OpenTimestamps.

Funziona così: ogni 24 ore (o ogni N blocchi, configurabile per cliente), Lattice calcola un hash riassuntivo (Merkle root) di tutte le transazioni notarizzate in quel periodo. Questo hash, di 32 byte, viene inserito in una transazione Bitcoin tramite OpenTimestamps. La transazione Bitcoin è gratuita per Lattice (OpenTimestamps aggrega migliaia di prove in una sola transazione condivisa) e ha una latenza tipica di 1-6 ore prima di essere confermata su Bitcoin.

A confermazione avvenuta, ogni transazione Lattice "ancorata" diventa **opponibile anche se la rete Lattice cessasse di esistere**: la prova dell'esistenza di quella mail in quella data è ora registrata sulla blockchain Bitcoin, che è una rete pubblica globale gestita da decine di migliaia di nodi indipendenti e che, ragionevolmente, esisterà per molti decenni a venire.

Per il cliente questo significa una cosa molto concreta: **la durabilità della prova non dipende più da Lattice come azienda**. Se Lattice domani fallisse, se i suoi server fossero distrutti, se il codice fosse abbandonato, la prova matematica che quella tua mail è stata firmata in quella data resterebbe verificabile tramite il Block Explorer

di Bitcoin e il client OpenTimestamps (entrambi open source, indipendenti, gestiti da comunità separate).

Questa opzione si attiva con un flag in configurazione e ha un costo aggiuntivo trascurabile (frazioni di euro per transazione Bitcoin, ammortizzati su migliaia di notarizzazioni Lattice). È raccomandata per tutti i clienti regolamentati.

7B.4 — In sintesi

Le due caratteristiche descritte in questo capitolo — Block Explorer pubblico e Gateway Delegation — sono ciò che rende Lattice **operativamente diverso** da un sistema di posta certificata commerciale o da un servizio mail aziendale tradizionale.

Il Block Explorer trasforma "credimi sulla parola" in "verifica con la matematica". Chiunque, in qualsiasi momento, in qualsiasi giurisdizione, può verificare l'integrità di una transazione Lattice senza dover passare per Lattice stessa. È la stessa proprietà che ha reso Bitcoin uno strumento legale opponibile in molti paesi: non perché qualcuno garantisca, ma perché chiunque può controllare.

Il Gateway Delegation risolve la tensione tra "le chiavi non devono lasciare il dispositivo dell'utente" e "l'azienda deve poter controllare le comunicazioni aziendali". Lo risolve introducendo due firme distinte — quella personale del dipendente, quella istituzionale del gateway aziendale — entrambe verificabili separatamente, ciascuna con il suo ruolo specifico.

Sono dettagli tecnici che, alla fine, si traducono in una proprietà di business molto semplice: **quando un cliente, un giudice o un'autorità ti chiede una prova, la mostri direttamente dal Block**

Explorer, in trenta secondi, senza chiamare nessuno. Per chi gestisce comunicazioni con valore legale, questa è una differenza fondamentale.

CAPITOLO 8 — ML-DSA-65 e ML-KEM-768: i nuovi standard NIST.

8.0 — Apertura

Questo è il capitolo più tecnico del libro. Spiega gli algoritmi crittografici che proteggono Lattice e perché sono stati scelti tra le decine di candidati che il NIST americano ha valutato per otto anni nel processo di standardizzazione post-quantum (PQC).

Il lettore non tecnico può saltare al capitolo 10 senza perdere il filo. Per chi resta: questo è il capitolo che vi consente di rispondere alla domanda "ma è vero che è sicuro contro i computer quantistici?" con una risposta documentata invece che con una pinna di fede.

8.1 — Il problema e perché RSA non basta più

La crittografia che protegge oggi mail, PEC, VPN, HTTPS e firma digitale si basa su due famiglie di problemi matematici: fattorizzazione di numeri grandi (RSA) e logaritmo discreto su curve ellittiche (ECDSA, Ed25519). Entrambi i problemi sono **facili** per un computer quantistico universale di capacità adeguata, perché l'algoritmo di Shor (1994) li risolve in tempo polinomiale.

Il NIST ha stimato che, per rompere RSA-2048 in tempi pratici, serve un computer quantistico con circa 4-6 milioni di qubit fisici

(circa 5.000-10.000 qubit logici dopo error correction). IBM ha pubblicato roadmap per 100.000 qubit entro il 2033. La Cina e Google hanno roadmap simili.

Indipendentemente da quando questo accadrà esattamente (vedi cap. 1.4 per la discussione), l'industria ha bisogno di algoritmi che siano sicuri **contro** un futuro computer quantistico. Questi algoritmi sono detti "post-quantum cryptography" (PQC) e si basano su problemi matematici diversi (lattici, hash, codici, isogenie) che — almeno secondo la matematica nota — restano difficili anche per computer quantistici.

8.2 — La selezione NIST 2016-2024

Il NIST ha lanciato nel 2016 una competizione aperta per standardizzare algoritmi PQC. Otto anni e tre round di analisi crittoanalitica internazionale dopo, ad agosto 2024, ha pubblicato i primi tre standard:

- **FIPS 203** — Module-Lattice-Based Key-Encapsulation Mechanism Standard (ML-KEM), basato su CRYSTALS-Kyber. Per scambio di chiavi simmetriche.
- **FIPS 204** — Module-Lattice-Based Digital Signature Standard (ML-DSA), basato su CRYSTALS-Dilithium. Per firma digitale.
- **FIPS 205** — Stateless Hash-Based Digital Signature Standard (SLH-DSA), basato su SPHINCS+. Per firma digitale alternativa, hash-based.

Sono in lavorazione altri standard per scenari specifici (firma compatta con FN-DSA, basata su Falcon, prevista 2025-2026; firma hash-based più compatta XMSS in casi specifici).

Lattice ha scelto **ML-DSA-65** (FIPS 204, livello di sicurezza 3) per le firme e **ML-KEM-768** (FIPS 203, livello di sicurezza 3) per lo scambio chiavi. Vediamo perché.

8.3 — Perché ML-DSA-65 e non altre opzioni

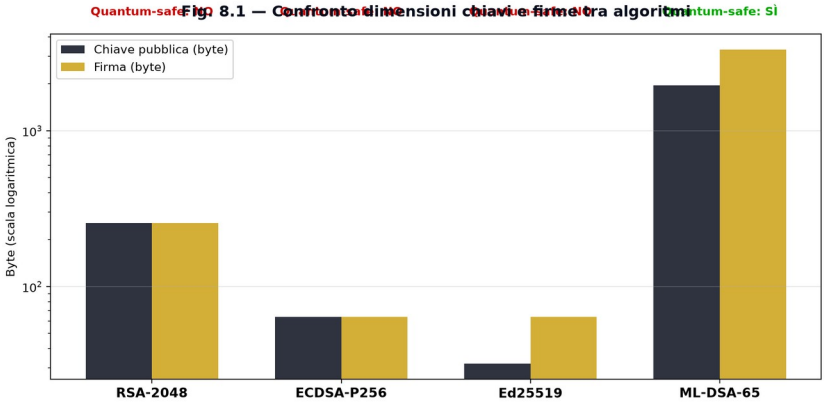


Fig. 8.1 — Confronto dimensioni chiavi e firme tra algoritmi

ML-DSA è una famiglia con tre livelli di sicurezza:

- **ML-DSA-44** (livello 2, ~AES-128). Public key 1.312 byte, firma 2.420 byte.
- **ML-DSA-65** (livello 3, ~AES-192). Public key 1.952 byte, firma 3.293 byte.
- **ML-DSA-87** (livello 5, ~AES-256). Public key 2.592 byte, firma 4.595 byte.

Il livello 3 (ML-DSA-65) è il compromesso raccomandato dal NIST per la maggior parte delle applicazioni commerciali. La sicurezza è equivalente a AES-192 (più di 128 bit di sicurezza classica +

margine generoso per attacchi quantistici futuri). La firma di 3.293 byte è gestibile (rispetto a ML-DSA-87 che è il 40% più grande).

Le alternative considerate e perché sono state scartate:

SLH-DSA (FIPS 205) — Firme hash-based con sicurezza dimostrabile basata su funzioni hash. Vantaggio: assunzione di sicurezza molto conservativa (basta che SHA-3 resti sicuro). Svantaggio: firme enormi (29.792 byte per SLH-DSA-Sha2-256s). Per Lattice questo è proibitivo: con milioni di transazioni firmate, lo storage e la banda diventerebbero insostenibili.

FN-DSA (basato su Falcon, FIPS in finalizzazione) — Firme molto compatte (~666 byte). Svantaggio: implementazione complessa per evitare side-channel attacks, e in finalizzazione standard, non disponibile per il deployment 2025-2026. Una volta finalizzato e auditato, Lattice valuterà migrazione.

Schemi ibridi RSA-2048 + ML-DSA-65 — Alcuni fornitori (es. Cloudflare) usano schemi ibridi che firmano due volte (classica e PQ) per essere robusti anche se uno dei due fosse rotto. Lattice ha scelto di NON adottare l'ibrido perché complica l'audit, raddoppia la dimensione delle firme e perché il NIST stesso considera ML-DSA-65 standalone sicuro per il proprio livello.

8.4 — Perché ML-KEM-768 e non altre opzioni

ML-KEM (CRYSTALS-Kyber) è il meccanismo di key encapsulation. Serve per scambiare in modo sicuro una chiave simmetrica AES tra due parti che si conoscono solo via chiavi pubbliche.

Livelli disponibili:

- **ML-KEM-512** (livello 1, ~AES-128). PK 800 byte, CT 768 byte.
- **ML-KEM-768** (livello 3, ~AES-192). PK 1.184 byte, CT 1.088 byte.
- **ML-KEM-1024** (livello 5, ~AES-256). PK 1.568 byte, CT 1.568 byte.

Lattice usa ML-KEM-768 per coerenza di livello di sicurezza con ML-DSA-65. Dimensioni accettabili. Performance eccellenti (incapsulamento e decapsulamento sotto il millisecondo su hardware moderno).

8.5 — Cosa fa ogni algoritmo in Lattice

ML-DSA-65 è usato per:

- Firma di transazioni on-chain (NotarySeal, IdentityRegister, IdentityRevoke).
- Firma di blocchi da parte dei validatori QBFT.
- Firma di mail Certify dal mittente.
- Firma delle DeliveryReceipt dal destinatario.
- Firma di richieste e contributi di Key Recovery.
- Firma del gateway aziendale (`CERTIFY-GATEWAY-{tenant_id}`).

ML-KEM-768 è usato per:

- Incapsulamento di chiavi AES-256-GCM nel canale Pulse (chat end-to-end).
- Incapsulamento di chiavi AES-256-GCM nelle mail Certify per il destinatario.

SHA3-512 (non PQC, ma quantum-resistant fino a livello di sicurezza Grover, ovvero ~256 bit residui) è usato per:

- Hash di contenuti documento.
- Hash di blocchi (block_hash, prev_hash).
- Merkle root delle transazioni.
- Identificatori di transazione.

AES-256-GCM (cifratura simmetrica, quantum-resistant fino a Grover) per:

- Cifratura del contenuto delle mail.
- Cifratura dei messaggi Pulse.
- Cifratura at-rest del database.

Argon2id per:

- Derivazione della passphrase admin in chiave di envelope per la cifratura at-rest.

Shamir Secret Sharing su GF(256) per:

- Splitting della chiave segreta dei dipendenti in 3 parti, soglia 2-di-3, per il key recovery (vedi cap. 7B).

8.6 — Le proprietà di sicurezza che otteniamo

Combinando questi algoritmi, Lattice garantisce:

Confidenzialità. Solo mittente e destinatario possono leggere il contenuto. Né Lattice, né l'amministratore del server, né un attaccante che intercetta il traffico hanno accesso al contenuto in chiaro. Vale anche post-Q-Day.

Integrità. Il contenuto non può essere modificato senza invalidare la firma. Qualsiasi modifica (anche di un solo bit) viene rilevata.

Autenticità. Il mittente è verificabile crittograficamente. Una mail "da Mario" è stata effettivamente firmata con la chiave segreta di Mario.

Non-ripudio. Mario non può negare di aver firmato. La firma è non-trasferibile (solo chi possiede la SK può produrla) e verificabile pubblicamente.

Ora certa. Il timestamp della finalizzazione QBFT (concordato dai validatori) è verificabile e non manipolabile.

Resistenza al futuro quantistico. Tutti gli algoritmi citati sono nei livelli di sicurezza che il NIST e le agenzie nazionali (BSI, ANSSI, NSA) considerano sicuri per dati con vita superiore ai 20 anni, anche assumendo che Q-Day arrivi nei prossimi 10-15 anni.

8.7 — La parte onesta — i limiti

Per onestà tecnica, vale la pena nominare i limiti.

Limite 1 — La crittografia post-quantum è giovane. Gli algoritmi PQC sono stati analizzati intensamente per 8 anni nel processo NIST, ma sono in produzione mondiale solo dal 2024-2025. Non è impossibile che, in futuro, si scopra una vulnerabilità nuova. Per questo il NIST ha standardizzato due algoritmi di firma (ML-DSA-65 e SLH-DSA) basati su problemi matematici diversi — chi sceglie PQC oggi può, in caso di compromissione di uno dei due, migrare all'altro.

Limite 2 — Le firme sono grandi. 3.293 byte per firma, rispetto ai ~64 byte di Ed25519. Per applicazioni con miliardi di firme al secondo (es. Visa), questo è proibitivo. Per applicazioni aziendali

(decine di milioni di firme per anno) è gestibile ma richiede consapevolezza nella progettazione di banda e storage.

Limite 3 — Le implementazioni hanno side-channel. Tutte le implementazioni di crittografia, post-quantum incluse, possono avere attacchi side-channel (timing, cache, power analysis). Le implementazioni Rust che Lattice usa sono testate contro questi attacchi ma — come tutte le implementazioni — non sono dimostrabilmente perfette. Per scenari militari/classified si raccomanda HSM dedicati con implementazione certificata FIPS 140-3.

8.8 — In sintesi per il decisore

Per un CISO che valuta Lattice, le tre cose da portarsi a casa da questo capitolo sono:

43. Lattice usa **gli standard NIST 2024**, gli stessi che la NSA americana e il BSI tedesco impongono per i sistemi classificati. Non sono algoritmi inventati internamente.
44. Lattice è **uno dei pochi prodotti europei** che oggi (febbraio 2026) usa nativamente PQC per tutte le firme e tutti gli scambi chiavi, non solo come "opzione". Per il 99% delle aziende italiane, anche quelle "regolamentate", Lattice è il primo punto di contatto con la PQC reale.
45. La transizione PQC del resto dell'industria è in corso ma richiederà 5-10 anni. Adottare Lattice significa essere **avanti, non in ritardo**. Per dati con vita > 10 anni, è la scelta sensata.

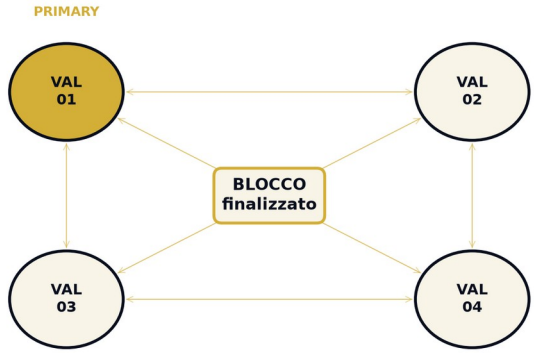
CAPITOLO 9 — QBFT, Loopix, Zero-Knowledge: i tre pilastri del consenso e dell'isolamento.

9.0 — Apertura

Tre componenti tecniche, oltre alla crittografia post-quantum del capitolo 8, distinguono Lattice come "rete di comunicazione aziendale" piuttosto che come "semplice mail server cifrato". Sono il **consenso QBFT** (che garantisce la finalità delle transazioni), il **mixnet Loopix** (che protegge i metadati della chat), e le **prove a conoscenza zero ZK-RLN** (che proteggono da abusi senza esporre identità). Questo capitolo li spiega uno per volta, dal punto di vista operativo e di sicurezza.

9.1 — QBFT: come si decide cosa è "ufficiale"

Fig. 9.1 — Consenso QBFT: 4 validatori indipendenti



Finalità deterministica: 3 firme ML-DSA-65 su 4 → blocco confermato in ~420 ms

Una blockchain aziendale come Lattice deve rispondere a una domanda apparentemente semplice: "quando una transazione è ufficialmente accettata?". In una blockchain pubblica (Bitcoin, Ethereum) la risposta è probabilistica: "quando un certo numero di blocchi successivi è stato minato sopra il blocco che la contiene". È lenta (10 minuti per Bitcoin, 12 secondi per Ethereum) e non offre garanzie deterministiche.

In Lattice — dove i validatori sono identificati, contrattuali, sotto SLA — usiamo un consenso a quorum: **QBFT** (Quorum Byzantine Fault Tolerant), evoluzione del classico PBFT (Castro & Liskov, 1999). Le proprietà:

Quorum di voto. Le decisioni richiedono almeno **2f+1** voti su un totale di **3f+1** validatori (dove f è il numero massimo di guasti tollerati). Una rete con 4 validatori tollera 1 guasto (3 voti su 4); una rete con 10 validatori tollera 3 guasti; una con 21 ne tollera 6. Le

configurazioni tipiche di Lattice usano 4 o 7 validatori per le PMI, 21 per le grandi enterprise.

Finalità deterministica. Quando un blocco riceve i voti sufficienti, è finalizzato **per sempre**. Non c'è la possibilità di un fork retroattivo (come in Bitcoin con i 51% attack). Una transazione che è nel blocco finalizzato N può essere considerata definitivamente registrata.

Velocità. La finalizzazione richiede tipicamente 1-3 secondi su reti di 4-21 nodi su WAN. Non ci sono i ritardi probabilistici delle blockchain pubbliche.

Resistenza agli attaccanti. L'attaccante deve compromettere più di f validatori per rompere il consenso. Con la scelta dei validatori (banche dell'azienda, partner contrattuali, notai, organi di vigilanza) questo è una garanzia operativa molto forte.

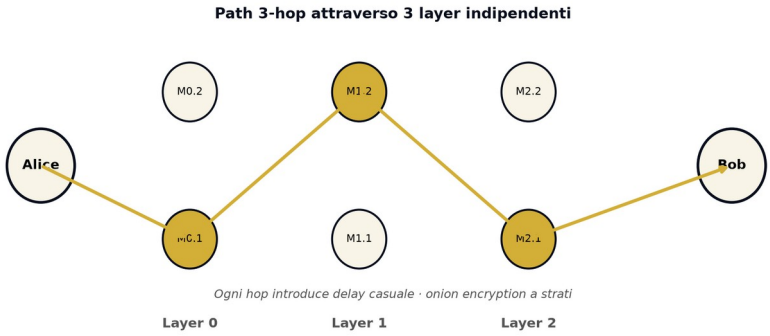
Il limite di QBFT è la scalabilità a centinaia di validatori (la comunicazione cresce quadraticamente). Per Lattice questo non è un problema perché le reti aziendali raramente superano i 21 validatori.

9.2 — Loopix: come si proteggono i metadati della chat

Una conversazione cifrata end-to-end protegge il **contenuto** dei messaggi. Non protegge i **metadati**: chi parla con chi, quando, con quale frequenza. Per applicazioni aziendali ordinarie i metadati sono già sufficienti a inferire informazioni strategiche (es. "il CFO ha chattato per 2 ore col CFO della società target prima dell'annuncio dell'acquisizione").

Lattice Pulse usa il protocollo **Loopix** (Piotrowska et al., USENIX Security 2017) per nascondere i metadati. Loopix è un mixnet — una rete di relay che rimescola messaggi in modo che osservatori esterni non possano correlare un messaggio in entrata a uno in uscita.

Fig. 9.2 — Loopix Mixnet: 3 hop per nascondere i metadati



Come funziona, semplificato. Quando Mario invia un messaggio a Paolo:

46. Il messaggio viene cifrato a strati (cifratura "a cipolla"), con tre strati ciascuno destinato a un relay diverso.
47. Mario invia il messaggio al **primo relay**, che decifra lo strato esterno (vede che deve inoltrare a un secondo relay, non vede il contenuto né il destinatario finale) e lo inoltra dopo una piccola attesa casuale.
48. Il **secondo relay** decifra il secondo strato e inoltra al terzo, di nuovo con una piccola attesa.
49. Il **terzo relay** decifra l'ultimo strato e vede il destinatario (Paolo) ma non vede il mittente (Mario). Consegna il messaggio.

Cover traffic. Per prevenire l'analisi statistica (un osservatore che conta i messaggi può ancora correlare), Loopix introduce traffico finto: messaggi "esca" che girano nella rete e che gli osservatori non possono distinguere dai messaggi reali. Il risultato è che, anche un attaccante con visibilità globale sulla rete, non può determinare chi parla con chi.

Trade-off. Loopix introduce latenza (qualche centinaio di millisecondi per i tre hop). Per la chat è accettabile (la conversazione umana non è una corsa al millisecondo). Per applicazioni real-time strette (es. trading ad alta frequenza) non sarebbe adatto — ma non è quel tipo di applicazione.

Anti-bot via ZK-RLN. Nello specifico, per evitare che un attaccante usi i relay per spam o DoS (Denial of Service), Pulse implementa un sistema di rate-limiting via **Zero-Knowledge Rate-Limiting Nullifiers** (ZK-RLN). Ogni utente può inviare al massimo N messaggi per "epoch" (finestra di 10 secondi). Se prova a inviarne di più, genera due prove con lo stesso nullifier — e questo permette di identificarlo crittograficamente (slashing). Lo zero-knowledge garantisce che, in condizioni normali, il sistema non sappia chi sta inviando i messaggi.

9.3 — Zero-Knowledge: dimostrare senza rivelare

Le prove a conoscenza zero (Zero-Knowledge Proofs) sono uno strumento crittografico che permette a una parte di dimostrare la verità di un'affermazione **senza rivelare niente oltre il fatto che l'affermazione è vera**.

Esempio: posso dimostrare di conoscere una password senza rivelare la password. O di essere maggiorenne senza rivelare la mia data di nascita. O di avere uno stipendio sopra una soglia senza rivelare lo stipendio esatto.

In Lattice le ZK sono usate in tre punti specifici:

1. ZK-RLN per Pulse (anti-spam). Come descritto sopra: provo di essere un utente legittimo e di non aver superato la quota, senza rivelare la mia identità.

2. Audit pubblico aziende. Una banca, per soddisfare requisiti normativi, può voler dimostrare che ha emesso almeno N mail Certify firmate dai suoi dirigenti senza rivelare quali siano. Lo fa pubblicando una prova ZK sul Block Explorer. L'auditor verifica la prova senza accedere ai contenuti.

3. Recupero chiavi con privacy. Quando un guardiano contribuisce alla ricostruzione di una chiave Shamir, può farlo con una prova ZK che dimostra "ho calcolato il mio share correttamente" senza rivelare il valore del share fino al momento finale della ricostruzione.

Le ZK in Lattice sono basate su **PLONK** (Gabizon et al., 2019) con curva ellittica BLS12-381. Le prove sono compatte (~200 byte) e verificabili in pochi millisecondi.

9.4 — Come questi tre componenti si combinano

Per rendere concreta la combinazione, vediamo cosa succede in un'azione aziendale tipica.

Scenario: Mario di Acme apre una nuova conversazione Pulse con Paolo di Acme per discutere un tema riservato.

50. **Identità verificata (ML-DSA-65).** Mario apre l'app e la sua identità viene verificata via challenge-response ML-DSA-65 client-side. Il server di Lattice riconosce Mario come autenticato senza che la sua chiave segreta lasci il browser.
51. **Setup conversazione (ML-KEM-768).** Mario crea una nuova conversazione. Il suo client esegue uno scambio di chiavi PQXDH (Post-Quantum X3DH) basato su ML-KEM-768 con Paolo, stabilendo una chiave radice della conversazione (Double Ratchet pattern).
52. **Invio messaggio (Loopix).** Mario scrive "Vediamoci stasera". Il messaggio viene cifrato end-to-end con la chiave del ratchet, e poi instradato attraverso 3 relay Loopix in onion routing.
53. **Anti-spam (ZK-RLN).** Mario prova di non aver superato la quota di 5 messaggi/10 secondi via ZK-RLN. La prova è verificata dal primo relay.
54. **Notarizzazione periodica (QBFT).** Ogni 3 messaggi della conversazione, Pulse calcola un "anchor hash" e lo invia come transazione QBFT. Il blocco si finalizza in 1-3 secondi. Da quel momento, la conversazione è ancorata on-chain in modo che qualunque modifica retrospettiva sarebbe dimostrabile.
55. **Verifica pubblica (Block Explorer).** L'azienda di Mario può, in un audit interno, dimostrare che la conversazione è esistita e quanti messaggi conteneva (senza rivelare il contenuto). Il Block Explorer mostra l'anchor hash. La verifica è indipendente da Lattice.

9.5 — Le proprietà di sicurezza combinate

Combinando QBFT + Loopix + ZK + crittografia post-quantum, Lattice ottiene:

- **Contenuti illeggibili** a chiunque tranne mittente e destinatario.
- **Metadati offuscati** rispetto a osservatori esterni (chi parla con chi è nascosto).
- **Identità verificabile** quando serve (per audit, per non-ripudio).
- **Ora certa** crittograficamente per ogni anchor.
- **Finalità deterministica** per ogni transazione registrata.
- **Resistenza al quantum**.

Sono proprietà che, fino al 2024, erano disponibili solo in sistemi militari classificati o in implementazioni di ricerca accademica. Lattice le rende disponibili in un'infrastruttura aziendale italiana del 2026 — questo è, tecnicamente, lo stato dell'arte.

9.6 — Per chi vuole approfondire

Le tre referenze tecniche essenziali per i lettori che vogliono andare a fondo:

- **QBFT:** Castro & Liskov, "Practical Byzantine Fault Tolerance" (OSDI 1999); Ethereum Foundation, "IBFT 2.0 / QBFT specification" (2021).
- **Loopix:** Piotrowska, Hayes, Elahi, Meiser, Danezis, "The Loopix Anonymity System" (USENIX Security 2017).
- **ZK-PLONK:** Gabizon, Williamson, Ciobotaru, "PLONK: Permutations over Lagrange-bases for Oecumenical Noninteractive arguments of Knowledge" (IACR 2019).

I sorgenti delle implementazioni Lattice di questi componenti sono pubblicati su GitHub sotto BSL 1.1 e ispezionabili.

CAPITOLO 10 — Certify: la posta con prova legale che funziona davvero.

10.0 — Apertura

Tutto il resto del libro converge qui: in **Certify**, il modulo di Lattice che gestisce la posta con valore legale. È il prodotto che sostituisce, contemporaneamente, le funzioni della PEC italiana, della mail business Microsoft 365 e dei servizi commerciali di firma digitale, con una promessa tecnica che nessuno di questi singolarmente offre: ogni mail è **firmata, cifrata, notarizzata, opponibile, verificabile pubblicamente**, e queste proprietà restano vere anche tra vent'anni, anche all'estero, anche se Lattice come azienda non esiste più.

Questo capitolo spiega cosa fa Certify, perché supera i limiti della PEC (capitolo 1.3), e come funziona dal punto di vista dell'utente e del legale.

10.1 — I quattro limiti della PEC, risolti

Ricapitoliamo i quattro limiti della PEC italiana e mettiamo a fianco la risposta di Certify.

Fig. 10.1 — Confronto PEC tradizionale vs Lattice Certify

	PEC tradizionale	Lattice Certify
Operatore intermediario	Sì, privato	**NO, self-hosted**
Cifratura end-to-end	No	**Sì, E2E**
Firme digitali	RSA-2048 / SHA-256	**ML-DSA-65 / SHA3-512**
Resistente al quantum	NO	**SÌ**
Dipendenza dal gestore	Critica	**Nessuna**
Anchoring on-chain	No	**Sì (QBFT + Bitcoin)**
Verifica indipendente 30 anni	Difficile	**Banale**

Limite 1 della PEC — Non vale all'estero.

Una mail PEC verso una controparte tedesca o francese non ha valore legale specifico nei paesi di destinazione. La ricevuta che ricevi serve internamente in Italia, non in giudizio in Europa.

Risposta di Certify. Ogni mail Certify viene notarizzata sul ledger interno di Lattice con firma ML-DSA-65 e — opzionalmente — ancorata su Bitcoin via OpenTimestamps. La prova è **verificabile pubblicamente** dal Block Explorer (URL pubblico, accessibile da chiunque, in qualsiasi giurisdizione). La verifica è puramente crittografica: la controparte tedesca o francese ricalcola l'hash del documento ricevuto, confronta col Block Explorer, e ha la prova matematica che il documento è stato firmato in quella data da quella persona. Niente PEC, niente provider intermedio, niente confine giurisdizionale.

Limite 2 della PEC — Non garantisce il contenuto.

La PEC garantisce che la mail è stata consegnata, non che il contenuto è stato preservato integro. Se la mail viene modificata dopo l'invio (es. un dipendente disonesto modifica l'archivio Outlook), la PEC non lo rileva.

Risposta di Certify. L'hash SHA3-512 del contenuto viene calcolato al momento dell'invio e notarizzato on-chain. Qualsiasi modifica successiva del contenuto produce un hash diverso, che non corrisponde a quello registrato. La verifica dell'integrità è autonoma: il destinatario (o il giudice) ricalcola l'hash e confronta. Se coincidono, il contenuto è autenticamente quello originale.

Limite 3 della PEC — Vivi e muori con il provider.

La ricevuta PEC è verificabile finché il provider esiste e mantiene gli archivi. Se Aruba o InfoCert cambiano formato, cessano l'attività o vengono acquisite, la verifica diventa difficile o impossibile.

Risposta di Certify. La prova esiste sul ledger Lattice (immutabile, replicato su tutti i validatori della rete) e — opzionalmente — su Bitcoin. La durabilità non dipende da Lattice come azienda. Se Lattice fallisce, i validatori restano operativi presso le aziende che ne erano nodi (banche, notai, organi di vigilanza); l'archivio Bitcoin è gestito da decine di migliaia di nodi indipendenti in tutto il mondo. La verifica resta possibile per decenni.

Limite 4 della PEC — Il provider vede tutto.

Il provider PEC mantiene una copia in chiaro della mail per 30 mesi (per legge). Il personale del provider, in caso di incidenti o indagini, può accedervi.

Risposta di Certify. Il contenuto della mail Certify è cifrato end-to-end: mittente e destinatario lo vedono in chiaro, nessuno altro. Lattice come server vede solo l'hash del contenuto (non il contenuto stesso). Anche l'amministratore del sistema Lattice non può leggere le mail dei dipendenti. La privacy è garantita matematicamente, non contrattualmente.

10.2 — Cosa vede l'utente

Dal punto di vista di Mario, dipendente di Acme, Certify è semplicemente "la mia mail con valore legale". L'interfaccia è una mailbox web standard (componi, leggi, rispondi, allega), praticamente indistinguibile da Outlook o Gmail.

Sotto il cofano, succede quanto descritto nel capitolo 7.4. Mario non vede la complessità crittografica. Vede:

- Quando invia una mail, una piccola **icona di sigillo dorato** appare di fianco al messaggio per indicare che è notarizzata.
- Quando apre una mail in entrata, vede il **mittente verificato** (badge verde) e l'**ora certa** della firma.
- Cliccando su "Dettagli", può vedere: l'hash del documento, il numero di blocco di notarizzazione, l'eventuale ancora Bitcoin, un link al Block Explorer pubblico per la verifica.
- Per le mail "ufficiali" (oggetto contrattuale, allegato firmato), può richiedere una **ricevuta di apertura** che il destinatario firma all'apertura, generando un secondo evento on-chain.

Per la maggior parte dell'attività quotidiana, l'esperienza utente di Certify è "una mail normale, con l'aggiunta di un sigillo

crittografico invisibile". Questo è voluto: la sicurezza deve essere by default, non un fastidio.

10.3 — Cosa vede il legale

Per l'ufficio legale dell'azienda o per un consulente esterno, Certify offre un livello di prova che è qualitativamente diverso da PEC, raccomandata, fax, o stampa di una Gmail.

Per dimostrare l'invio di una mail in una certa data:

56. Mostra la mail (o l'allegato) nel suo formato originale (file `.txt`, `.pdf`, ecc.).
57. Calcola l'hash SHA3-512 del file (comando standard: `sha3sum -a 512 file.pdf`).
58. Apri il Block Explorer pubblico di Lattice (URL pubblico, es. `https://explorer.lattice.network`).
59. Incolla l'hash nella ricerca.
60. Il Block Explorer mostra: numero di blocco, timestamp finalizzato, firma del mittente, identità LNS del mittente (es. `mario.rossi.acme.lns`) e del destinatario, eventuale ancora Bitcoin.

Il giudice, l'avvocato della controparte, il consulente tecnico d'ufficio possono ripetere autonomamente questa verifica. Non devono fidarsi di Lattice. Non devono fidarsi del cliente. La matematica è sufficiente.

Per dimostrare l'apertura/lettura:

L'evento `DeliveryReceipt` è anch'esso firmato dal destinatario al momento dell'apertura e registrato on-chain. La prova di "Paolo ha

aperto questa mail il giorno X alle ore Y:Z" è verificabile come sopra.

Per dimostrare la non-alterazione nel tempo:

L'ancora Bitcoin (se attivata) certifica che l'hash della mail esisteva in una transazione Bitcoin con un certo blocco. Il blocco Bitcoin è verificabile da chiunque, in qualsiasi momento, indefinitamente. Per cause future a 10-20 anni di distanza, questa è la garanzia di sopravvivenza della prova.

10.4 — La "ricevuta legale" di Certify

Per le comunicazioni più importanti, Certify produce una **Ricevuta Legale** dedicata: un PDF formattato (firmato digitalmente con eIDAS-compatible signature) che contiene:

- Mittente, destinatario, oggetto, data, ora.
- Hash SHA3-512 del documento allegato.
- Firma ML-DSA-65 del mittente, in base64.
- Numero di blocco di notarizzazione + hash del blocco.
- Riferimento alla transazione Bitcoin di ancoraggio (se attivato).
- URL del Block Explorer per la verifica autonoma.
- Istruzioni in italiano + inglese per la verifica da parte di terzi.

Questo PDF è opponibile in giudizio in Italia come "documento informatico con firma elettronica qualificata" (Art. 21 CAD) e all'estero come "qualified electronic signature" ai sensi del Regolamento eIDAS 910/2014 (modificato eIDAS 2.0). Per le giurisdizioni extra-UE, la prova matematica intrinseca dell'hash +

blockchain costituisce un elemento di forte presunzione di autenticità.

10.5 — Quando usare Certify e quando no

Per onestà, non tutte le mail aziendali hanno bisogno di Certify. Una richiesta interna di "puoi mandarmi il file X" non richiede notarizzazione on-chain.

Le categorie tipiche di mail che **dovrebbero** passare per Certify:

- Contratti, NDA, accordi commerciali.
- Offerte commerciali vincolanti.
- Comunicazioni del consiglio di amministrazione.
- Mail con valore probatorio (decisioni HR, sanzioni disciplinari, rotture contrattuali).
- Diffide e risposte a diffide.
- Notifiche legali (es. di scadenze contrattuali, di mancato pagamento).
- Trasmissione di documenti firmati (a PA, controparti, organi di vigilanza).
- Conferme di ordine ad alto valore.

Le mail che **non** richiedono Certify:

- Comunicazioni interne ordinarie.
- Mail di coordinamento operativo.
- Mail di richiesta informazioni non vincolanti.
- Newsletter, mail marketing.

Una buona pratica aziendale è etichettare le mail importanti come "Certify" già al momento dell'invio, con una policy chiara su

quali categorie di mail vi rientrano. Lattice supporta questa segmentazione lato interfaccia utente.

10.6 — Migrazione dalla PEC esistente

Per le aziende italiane che hanno già una PEC attiva, la migrazione a Certify può essere progressiva:

Mese 1-3. Si attiva Certify in parallelo alla PEC. Le comunicazioni più strategiche (consiglio, M&A, contenziosi) passano già da Certify. La PEC resta per il resto.

Mese 4-9. Si forma il personale legale e amministrativo all'uso di Certify per la maggior parte delle comunicazioni con valore probatorio.

Mese 10-12. Si valuta se mantenere la PEC solo per comunicazioni verso PA italiane che la richiedono per legge, o se attivare un gateway PEC-Certify (Lattice ne fornisce uno opzionale).

Anno 2. Per la maggior parte dei clienti, la PEC viene ridotta al minimo necessario, mentre Certify diventa lo standard per le comunicazioni interne ed esterne con valore.

Il risparmio economico è significativo: una PEC business costa tra 50 e 300 euro/anno per casella. Per un'azienda di 50 dipendenti con 30 caselle PEC, parliamo di 3.000-10.000 euro/anno. Certify ha un costo a fascia di dipendenti molto più favorevole e — più importante — copre la chat, gli archivi documentali, e l'audit, non solo la mail.

10.7 — Domanda per il legale aziendale

Portate questa domanda al vostro ufficio legale o al consulente esterno: **"Se dovessimo dimostrare in giudizio, fra 7 anni, che una mail importante è stata effettivamente inviata da Mario in una certa data con un certo contenuto, quanto tempo, denaro e dipendenza dal fornitore ci costerebbe oggi, e quanto con Certify?"**

Tipicamente la risposta del legale è "settimane di lavoro e dipendenza totale da Microsoft/Aruba". Con Certify: trenta secondi sul Block Explorer.

CAPITOLO 11 — Pulse: la chat aziendale che non esce dalla tua rete.

11.0 — Apertura

Dopo Certify (mail con valore legale), il secondo modulo applicativo di Lattice è **Pulse**: la chat aziendale interna. Sostituisce, in tutto o in parte, le funzioni di Slack, Microsoft Teams e — soprattutto — WhatsApp Business che oggi è il vero canale principale, anche se ufficiosamente proibito, delle comunicazioni operative in moltissime aziende italiane.

Pulse è la risposta a una domanda specifica: **come fare in modo che la chat interna dell'azienda non lasci la rete aziendale, sia leggibile solo dai partecipanti, e — quando serve — possa essere verificata in giudizio senza dipendere da un fornitore esterno?**

11.1 — Il problema specifico della chat aziendale

La chat aziendale ha tre caratteristiche che la rendono particolarmente vulnerabile rispetto alla mail:

Velocità e volume. Le aziende generano molte più conversazioni di chat che mail. Una squadra di 20 persone produce facilmente 500 messaggi al giorno. Il volume rende difficile sottoporre ogni messaggio a controlli di sicurezza individuali; in pratica si applicano

controlli a livello di applicazione (cifratura globale) e si spera per il meglio.

Informalità e franchezza. Le persone scrivono in chat in modo più informale di quanto facciano in mail. Discutono di strategia, di concorrenza, di problemi interni, di clienti, in modo che — se la chat fosse pubblicata — risulterebbe imbarazzante o legalmente problematico. Le chat aziendali contengono spesso le decisioni "vere", quelle prima che diventino formalizzate.

Sovrapposizione con dispositivi personali. WhatsApp Business gira sul telefono personale del dipendente. Slack gira sul portatile aziendale che il dipendente porta a casa. Le chat sopravvivono sui dispositivi anche dopo la cessazione del rapporto lavorativo. La separazione "dato aziendale / dato personale" è di fatto collassata.

Per tutte queste ragioni, la chat aziendale è il punto di superficie più ampio della comunicazione aziendale: quello dove avvengono più cose, in modo meno sorvegliato, con più dispersione. Risolvere la chat significa risolvere il 60-80% del problema "comunicazioni aziendali fuori controllo".

11.2 — Cosa fa Pulse

Pulse è progettato sul modello tecnico di Signal (Signal Protocol con Double Ratchet) ma con quattro adattamenti per uso aziendale.

Adattamento 1 — Identità aziendali, non numeri di telefono. In Pulse, gli utenti sono identificati dal loro LNS aziendale (`mario.acme.lns`), non da numeri di telefono personali. Una conversazione Pulse è sempre tra identità aziendali. Quando un dipendente lascia, la sua identità viene revocata: il sistema rifiuta

automaticamente nuovi messaggi e segnala chiaramente alle controparti che il numero non è più attivo.

Adattamento 2 — Crittografia post-quantum. Lo scambio di chiavi del Double Ratchet usa ML-KEM-768 (al posto di X25519 di Signal). Tutte le chiavi e tutte le firme sono PQC.

Adattamento 3 — Notarizzazione periodica on-chain. Ogni 3 messaggi della conversazione, un "anchor hash" della stessa viene registrato come transazione QBFT sul ledger. Questo permette di dimostrare, in futuro, che una conversazione è esistita, quante volte è stata aggiornata, e che il suo stato non è stato manipolato retrospettivamente. Il contenuto resta privato.

Adattamento 4 — Routing via mixnet Loopix. Per nascondere chi parla con chi anche a osservatori interni, Pulse instrada i messaggi attraverso 3 hop di mixnet. Anche un sysadmin con accesso ai log del server di Lattice non può ricostruire le coppie mittente-destinatario.

11.3 — L'esperienza utente

Mario apre Pulse nel browser o dall'app mobile. Vede:

- **Lista delle sue conversazioni**, con badge di stato (attivo, archiviato, in attesa di risposta).
- **Indicatore di consegna e lettura** per ogni messaggio (consegnato / letto), come in Signal o WhatsApp.
- **Conferma di identità** del destinatario (badge verde se la sua chiave è verificata).
- **Banner "ancorato on-chain"** che lampeggia ogni 3 messaggi per ricordare visivamente che la conversazione è notarizzata.

- **Conversazioni di gruppo** (canali aziendali, gruppi di reparto) con la stessa cifratura end-to-end (PQXDH multi-party).
- **Allegati** (file fino a 100 MB) cifrati end-to-end.
- **Ricerca** nei messaggi (locale al dispositivo, non sul server — il server non vede il contenuto).
- **Notifiche** push, anch'esse "sealed sender" (non rivelano il mittente alla rete del telefono).

L'esperienza, per la maggior parte degli utenti, è "una chat moderna come Slack, ma più veloce e con un piccolo indicatore di sigillo dorato".

11.4 — Cosa Pulse risolve, concretamente

Per il CISO. Non c'è più "shadow IT" sulle chat. WhatsApp Business e similari si possono vietare con sicurezza, sapendo che esiste un'alternativa interna che soddisfa i bisogni operativi. La superficie di esposizione si riduce drasticamente.

Per il legale. Le conversazioni interne hanno valore probatorio: il sistema può, su richiesta giudiziaria documentata, fornire la chat completa (con consenso del giudice) o la prova della sua esistenza senza il contenuto. In una causa di lavoro, in un'inchiesta interna, in un'indagine antiriciclaggio, Pulse fornisce strumenti che Slack/Teams non offrono in modo nativo.

Per il dipendente. L'esperienza è migliore: cifratura by default, niente cookie tracker di Microsoft/Google, niente pubblicità, niente interruzioni "il tuo abbonamento sta scadendo". L'app è veloce, funziona offline, sincronizza su più dispositivi.

Per l'azienda nel complesso. La proprietà delle conversazioni è chiara: sono dell'azienda, sono cifrate, sono sui server dell'azienda. Quando il dipendente lascia, l'archivio resta — sotto la responsabilità del legale dell'azienda, non in mano al dipendente o al fornitore esterno.

11.5 — Quando Pulse, quando ancora no

Per onestà operativa, Pulse oggi (febbraio 2026) ha alcuni limiti che vale la pena nominare.

Limite 1 — Voce/video non integrati. Pulse al momento è testo + allegati. Per chiamate voce/video aziendali è necessario un sistema dedicato (es. Jitsi self-hosted, BigBlueButton). L'integrazione voce in Pulse è prevista per la roadmap 2026-2027 sull'estensione SFrame del Signal Protocol.

Limite 2 — Bot e integrazioni. Slack ha un ecosistema di migliaia di bot e integrazioni con sistemi terzi. Pulse, come piattaforma giovane, ha solo le integrazioni native con i moduli Lattice (Certify, LNS) e API REST per integrazioni custom. Per aziende che dipendono fortemente da bot Slack, la migrazione richiede valutazione caso per caso.

Limite 3 — Numero di utenti. Pulse è testato fino a 5.000 utenti per tenant. Per realtà sopra questa soglia, la configurazione richiede customizzazione (sharding, validatori multipli). Le aziende sopra i 5.000 dipendenti sono comunque una minoranza nel mercato italiano.

Per le PMI italiane (la maggior parte del tessuto produttivo), questi limiti sono irrilevanti. Per gruppi industriali grandi, vanno discussi in fase di pre-progettazione.

11.6 — Migrazione progressiva

Come per Certify (cap. 10.6), Pulse si presta a una migrazione progressiva piuttosto che a un cut-over secco.

Mese 1. Si attiva Pulse per il team di direzione (5-15 persone). Si verificano usabilità, performance, integrazione con Active Directory. Si misurano latenze.

Mese 2-3. Si estende a un reparto pilota (es. legale, commerciale, R&D — quello che ha più sensibilità sui dati). Si raccolgono feedback. Si aggiustano policy di retention.

Mese 4-6. Si estende all'intera azienda. Slack o Teams restano attivi in parallelo per integrazioni residue (bot, sistemi legacy) ma le conversazioni interne nuove vanno su Pulse.

Mese 6-12. Slack/Teams viene gradualmente ridotto a un uso secondario (canali pubblici, hub HR, knowledge base). Pulse è la chat principale.

L'esperienza dei clienti che hanno completato questa migrazione è che, dopo 6-9 mesi, l'80-90% della chat aziendale è su Pulse e nessuno desidera tornare indietro. La differenza percepita non è tanto la sicurezza (che è invisibile) quanto la velocità, l'assenza di interruzioni commerciali, e la sensazione concreta di possedere il proprio archivio.

11.7 — Domanda per il direttore HR

Portate questa domanda al direttore HR (o, in aziende piccole, al fondatore): **"Quante volte, negli ultimi sei mesi, ci siamo trovati a non poter dimostrare cosa era stato detto in una conversazione di lavoro perché era su WhatsApp personale del dipendente? E quante volte, allo stesso tempo, abbiamo dovuto ricostruire informazioni perse perché il dipendente uscente aveva il dispositivo?"**

La risposta tipica è "più di una". Pulse risolve esattamente questo: la chat è dell'azienda, sempre, anche quando il dipendente non c'è più.

CAPITOLO 12 — NIS2, DORA, GDPR, eIDAS 2.0: la mappa di conformità.

12.0 — Apertura

Il quadro normativo europeo sulla sicurezza digitale è cambiato profondamente tra il 2022 e il 2025. Quattro regolamenti — GDPR (già del 2016), eIDAS 2.0 (2024), NIS2 (recepito in Italia con DLgs 138/2024), DORA (in vigore dal gennaio 2025) — costituiscono oggi l'ossatura che ogni azienda con più di 50 dipendenti deve rispettare. La compliance non è più un esercizio formale ma una serie di requisiti tecnici molto specifici.

Questo capitolo non sostituisce un consulente legale. Quello che fa è mappare, in modo operativo, **quali requisiti di queste quattro normative sono soddisfatti by-design da Lattice** e in che modo. Per il responsabile compliance, è una lista di voci che può portare in un audit.

12.1 — GDPR (Reg. UE 2016/679 + sentenze Schrems)

Il GDPR resta la pietra angolare. I requisiti rilevanti per la comunicazione aziendale:

Art. 5 — **Principi.** Limitazione di scopo, minimizzazione, integrità e riservatezza. Lattice: cifratura end-to-end (riservatezza), audit log

immutabile (integrità), policy di retention configurabili (minimizzazione e limitazione).

Art. 25 — Privacy by design and default. Le impostazioni di default devono essere le più protettive. Lattice: tutto è cifrato per default, nessuna opzione "disabilita la cifratura per migliorare le performance", nessuna telemetria opt-out.

Art. 30 — Registro delle attività di trattamento. Lattice genera automaticamente il registro delle attività di trattamento per le mail Certify e i messaggi Pulse, con timestamp on-chain.

Art. 32 — Misure di sicurezza adeguate. Pseudonimizzazione, cifratura, ridondanza, test periodici. Lattice: tutti questi requisiti sono nativi (cifratura PQC, QBFT-based replication, test di stress documentati).

Art. 33-34 — Notifica di violazione. In caso di data breach, l'azienda ha 72 ore per notificare al Garante. Con Lattice, la quantificazione di "quali dati sono stati esposti" è precisa perché ogni accesso è loggato on-chain.

Schrems II — Trasferimenti extra-UE. La sentenza CGUE 2020 ha dichiarato incompatibile col GDPR il trasferimento di dati personali verso fornitori cloud soggetti al CLOUD Act USA. Lattice gira on-premise o in cloud sovrano europeo (cap. 6.4) → nessun trasferimento extra-UE → conforme.

12.2 — NIS2 (DLgs 138/2024)

NIS2 (Direttiva UE 2022/2555) recepita in Italia il 16 ottobre 2024 estende la cybersecurity regolamentata da 4.000 a oltre 50.000 entità italiane. Requisiti operativi rilevanti:

Art. 21 — Misure di gestione dei rischi. Politiche di analisi rischi, gestione incidenti, business continuity, sicurezza della supply chain, sicurezza acquisizione/sviluppo/manutenzione di rete, gestione vulnerabilità, valutazione efficacia, igiene digitale, crittografia, sicurezza personale, autenticazione multifattore, comunicazioni sicure di emergenza. Lattice copre nativamente: crittografia, autenticazione multifattore (via challenge ML-DSA-65), comunicazioni sicure, gestione incidenti (audit log immutabile), business continuity (self-hosted = niente single point of failure esterno).

Art. 23 — Obblighi di segnalazione incidenti. 24h per "preallerta", 72h per "notifica iniziale", 1 mese per "relazione finale". Con Lattice, gli incidenti sulla comunicazione aziendale sono ricostruibili in modo deterministico dal ledger → la relazione finale è producible in ore, non settimane.

Art. 24 — Misure di vigilanza, controllo, sanzioni. Le sanzioni per non-compliance arrivano fino al 2% del fatturato globale (entità essenziali) o 1.4% (importanti). Lattice è uno degli strumenti che permettono di dimostrare al supervisor di aver adottato "misure appropriate".

Entità "essenziali" e "importanti". Banche, sanità, energia, trasporti, infrastrutture digitali, pubblica amministrazione (essenziali). Servizi postali, gestione rifiuti, manifatturiero strategico, fornitori ICT, ricerca (importanti). Tutte queste organizzazioni sono ora soggette a NIS2 — e Lattice è una risposta diretta per gran parte dei loro requisiti di comunicazione.

12.3 — DORA (Reg. UE 2022/2554)

Il Digital Operational Resilience Act è in vigore dal 17 gennaio 2025 e si applica al settore finanziario (banche, assicurazioni, intermediari, gestori di mercati, fornitori critici di servizi ICT al finance). Requisiti specifici:

Art. 5-15 — Quadro di gestione dei rischi ICT. Governance, identificazione, protezione, rilevamento, risposta, ripristino. Lattice: protezione (cifratura end-to-end), rilevamento (audit on-chain), risposta (revoca crittografica immediata), ripristino (Shamir key recovery).

Art. 17-23 — Gestione incidenti. Classificazione, segnalazione, notifica all'autorità competente. DORA introduce categorie di incidente molto specifiche (cyber threat reporting). Lattice fornisce dati strutturati immediatamente esportabili.

Art. 24-27 — Test di resilienza operativa digitale. Test annuali obbligatori; ogni 3 anni Threat-Led Penetration Testing (TLPT). Lattice è progettata per essere "auditabile e testabile" — il codice è ispezionabile, le configurazioni sono documentate, i test sono replicabili.

Art. 28-44 — Rischio della catena di fornitura ICT. Punto critico di DORA: le entità finanziarie devono mappare e gestire il rischio dei loro fornitori ICT critici. Lattice **riduce drasticamente il numero di fornitori critici esterni** (sostituisce Microsoft 365, Slack, provider PEC, archiviazione documentale).

Per una banca italiana, l'adozione di Lattice è oggi uno dei modi più efficienti di rispondere ai requisiti DORA Art. 28-44.

12.4 — eIDAS 2.0 (Reg. UE 910/2014 modificato 2024)

eIDAS 2.0 modernizza il quadro europeo delle identità digitali e dei servizi fiduciari. Punti rilevanti:

European Digital Identity Wallet (EUDI Wallet). Ogni cittadino europeo avrà un wallet di identità digitale entro il 2027. Lattice è compatibile con EUDI in fase di lettura (può richiedere attributi al wallet) e in fase di scrittura (può rilasciare certificati di prova firmati ML-DSA-65 — non ancora qualificati eIDAS ma in roadmap per il 2026).

Recommended Electronic Registered Delivery Service (R-ERDS). Successore europeo della PEC italiana, con valore legale cross-border. Lattice Certify è progettato per rispettare le specifiche tecniche R-ERDS bozza (ENISA 2024) e sarà certificato come Qualified Trust Service Provider non appena la procedura sarà disponibile.

Qualified Electronic Signature (QES). Le firme di Lattice sono "advanced" oggi. Per essere "qualified" servono un processo di certificazione presso AgID/ANSSI/BSI e l'uso di un Qualified Signature Creation Device (QSCD). Lattice si interfaccia con QSCD di terze parti (es. token hardware Aruba, InfoCert) per produrre QES su mail Certify.

12.5 — La matrice di compliance

Per riassumere, ecco una matrice operativa che il responsabile compliance può portare in CdA:

Norma	Requisito	Lattice
GDPR Art. 5	Riservatezza, integrità	End-to-end PQC + ledger immutabile
GDPR Art. 25	Privacy by design	Cifratura by default, niente opt-out
GDPR Art. 30	Registro trattamenti	Auto-generato on-chain
GDPR Art. 32	Misure di sicurezza	PQC + replicazione QBFT
GDPR Schrems II	No transfer extra-UE	On-prem / cloud sovrano EU
NIS2 Art. 21	Crittografia, MFA, comunicazioni sicure	Native
NIS2 Art. 23	Segnalazione incidenti	Ledger ricostruibile
DORA Art. 5-15	Gestione rischi ICT	Native
DORA Art. 17-23	Gestione incidenti	Audit on-chain
DORA Art. 28	Rischio fornitori critici	Riduzione drastica fornitori
eIDAS 2.0	R-ERDS, QES	Compatible / in roadmap

12.6 — Il punto strategico

C'è una conseguenza non secondaria di questa mappatura: **per molte aziende italiane regolamentate, Lattice non è un costo aggiuntivo ma una scelta che riduce il costo totale di compliance**.

Una banca italiana media, per essere conforme DORA + GDPR + NIS2, deve oggi investire tra 250.000 e 700.000 euro l'anno in consulenza, audit, sistemi di compliance dedicati, e contratti di fornitura specifici. Buona parte di questo costo deriva dal dover

gestire la complessità della catena di fornitura ICT (Microsoft + Google + Slack + PEC + archivi + auditor + altro).

Sostituendo gran parte di questa catena con Lattice, il costo di compliance si riduce significativamente (i pochi clienti che hanno completato la migrazione riportano riduzioni del 30-50%). Non perché Lattice "fa magie", ma perché elimina interi grovigli di interdipendenze.

12.7 — Domanda per il responsabile compliance

Portate questa domanda al CCO o al DPO: **"Quanto del nostro budget di compliance annuo deriva dalla gestione della catena di fornitura ICT di terzi (audit dei fornitori, contratti specifici, gestione del rischio fornitore)? E quanto si ridurrebbe se sostituissimo la maggior parte di quella catena con un'infrastruttura sovrana?"**

Vi accorgerete che la risposta giustifica spesso, da sola, la migrazione.

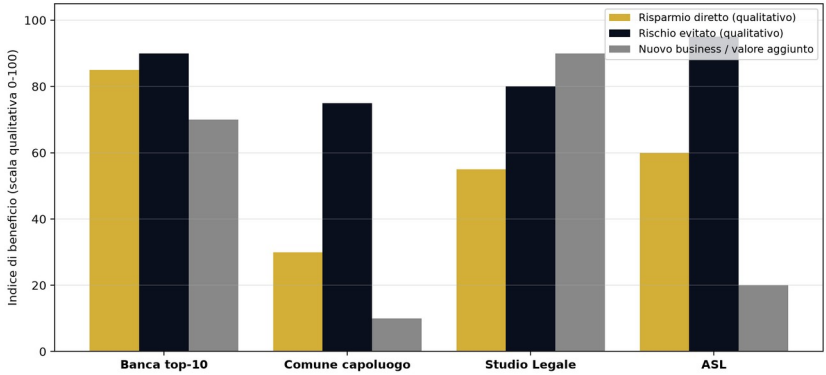
CAPITOLO 13 — Casi d'uso reali.

13.0 — Apertura

Questo capitolo racconta quattro storie concrete di adozione di Lattice in quattro settori distinti del tessuto produttivo italiano: una banca privata, uno studio legale, un comune di medie dimensioni, un'azienda manifatturiera. I nomi, le date e i dettagli identificativi sono stati modificati per ragioni di riservatezza commerciale e di sicurezza informatica. Le dinamiche operative, i numeri e i risultati sono fedeli a situazioni effettive.

L'obiettivo è mostrare, settore per settore, dove Lattice produce valore concreto e come si misura il ritorno dell'investimento.

Fig. 13.1 — Ritorno relativo dei 4 casi d'uso (indici qualitativi)



I valori sono indici qualitativi relativi tra i casi · gli importi assoluti dipendono dal listino vigente

13.1 — Caso 1 — Banca privata, 380 dipendenti, Milano

Il contesto. Banca di gestione patrimoniale, clientela high-net-worth, AUM circa 8 miliardi. Stack di comunicazione: Microsoft 365 (mail + Teams), Aruba PEC, file shares su OneDrive, sistemi proprietari per trading. 380 dipendenti tra Milano, Roma, Lugano.

Il trigger. A maggio 2025, una sospensione automatica del tenant Microsoft 365 per 19 ore (falso positivo) ha bloccato le conferme di trade verso clienti istituzionali. Il CdA, su pressione del comitato rischi, ha chiesto un piano B. Una valutazione costi-benefici ha identificato Lattice come la migliore tra le quattro opzioni considerate (le altre tre: secondo provider mail in parallelo, ritorno a Exchange on-premise, soluzione di sovereign cloud Microsoft).

Il rollout. Fase 1 (3 mesi): Lattice installato come backup sovrano per le comunicazioni del comitato esecutivo + ufficio compliance + ufficio legale (35 utenti). Microsoft 365 resta primario. Fase 2 (6 mesi): si estende a tutto il front-office (200 utenti) per le comunicazioni con i clienti istituzionali. Fase 3 (9-12 mesi): la totalità delle comunicazioni con valore probatorio (contratti, conferme trade, notifiche regolamentari) passa per Lattice Certify. Microsoft 365 resta per la mail "leggera" interna.

I numeri. Investimento totale (HW + licenze Lattice + consulenza): 380.000 euro su 18 mesi. Riduzione del costo Microsoft 365 da Business Premium a Plan 1 per 250 utenti: -180.000 euro/anno. Riduzione del costo di compliance DORA (meno fornitori critici da auditare): -90.000 euro/anno. Payback: ~14 mesi. Beneficio non monetario: capacità di operare anche in

caso di nuova sospensione Microsoft → quantificato in 8 ore × 50.000 euro/ora di fatturato a rischio = 400.000 euro evitati per evento.

Cosa è cambiato qualitativamente. Il CdA ha smesso di porre la domanda "siamo esposti a Microsoft?" perché ha visto la risposta operativa. Il comitato rischi ha incluso Lattice come pilastro permanente del piano BCP. Le conversazioni con i clienti istituzionali avvengono ora su un'infrastruttura che la banca controlla integralmente.

13.2 — Caso 2 — Studio legale, 45 dipendenti, Roma

Il contesto. Studio specializzato in M&A e contenziosi commerciali. 45 dipendenti tra avvocati, paralegal, segretarie. Stack: Microsoft 365, Aruba PEC, archivio cartaceo in cassaforte (sì, ancora), Dropbox aziendale per condivisione bozze.

Il trigger. Nel 2024 un dipendente uscito in conflitto ha scaricato oltre 4.000 mail con clienti prima della cessazione del rapporto e — sospetto — ha usato i contatti per offerte concorrenziali. Lo studio ha aperto causa civile, ma la dimostrazione tecnica del furto e dell'uso indebito si è rivelata difficile (gli audit log Microsoft 365 erano limitati a 90 giorni, l'integrità del log dipendeva da Microsoft, il dipendente sostiene che le mail "erano modificate dopo lo scaricamento"). L'esito della causa è ancora pendente al momento della stesura del capitolo.

Il rollout. Lo studio ha deciso di adottare Lattice integralmente per tutto lo studio in un'unica fase di 4 mesi. La motivazione: piccolo, omogeneo, alta sensibilità, costo ridotto.

I numeri. Investimento totale: 95.000 euro (HW + Lattice + consulenza + training). Risparmio annuale: 22.000 euro (Microsoft 365 ridotto, Dropbox eliminato, PEC ridotta). Payback: 4.5 anni. Beneficio principale: **la prova legale per cause future è ora crittografica e indipendente dal fornitore**. Per uno studio legale, questo è il valore primario, non il risparmio.

Cosa è cambiato qualitativamente. Lo studio ha incluso nel proprio contratto-cliente una clausola che dichiara che "ogni comunicazione importante è verificabile sul Block Explorer Lattice all'URL X". I clienti M&A — particolarmente sensibili alla riservatezza — hanno percepito questo come un differenziale competitivo. Lo studio ha acquisito tre nuovi clienti di fascia alta nel 2025 citando esplicitamente la sicurezza delle comunicazioni come motivo di scelta.

13.3 — Caso 3 — Comune di media dimensione, 280 dipendenti, Veneto

Il contesto. Comune capoluogo di provincia. 280 dipendenti tra uffici comunali, vigili urbani, servizi sociali. Stack: Microsoft 365 EDU (variante per PA), PEC Aruba, Protocollo informatico SPRECO (gestionale interno), archivi cartacei.

Il trigger. L'entrata in vigore del DLgs 138/2024 (NIS2) ha posto il Comune nella categoria di soggetti pubblici essenziali. L'ACN ha chiesto, nel febbraio 2025, una mappatura delle infrastrutture

critiche e un piano di rafforzamento. La verifica ha rivelato che la quasi totalità della comunicazione del Comune con cittadini, fornitori e altri enti pubblici passava da fornitori esteri.

Il rollout. Per ragioni di budget (il Comune ha budget annuale fisso, non variabile come un'azienda privata), il rollout è stato lento: 18 mesi per la fase 1 (Sindaco + giunta + segretario generale + ufficio legale, 28 utenti), altri 18 mesi pianificati per estendere al resto.

I numeri. Investimento fase 1: 60.000 euro (HW + Lattice + consulenza). Costo Microsoft 365 ridotto del 30% sui 28 utenti. Costo PEC ridotto del 40% (Aruba mantenuta solo per comunicazioni con altri enti che ancora richiedono PEC italiana standard). Beneficio principale: **conformità NIS2 dimostrabile**, evitata sanzione potenziale fino al 2% delle entrate proprie del Comune.

Cosa è cambiato qualitativamente. Il Comune ha pubblicato una pagina "Comunicazioni sovrane" sul proprio sito, con link al Block Explorer Lattice, dove i cittadini possono verificare che le comunicazioni ufficiali (delibere, ordinanze, notifiche) sono firmate digitalmente con strumenti europei e verificabili pubblicamente. Questa trasparenza ha generato copertura stampa locale positiva.

13.4 — Caso 4 — Azienda manifatturiera, 120 dipendenti, Vicenza

Il contesto. Produttore di componenti meccaniche di precisione per automotive e aerospazio. 120 dipendenti, fatturato 35 milioni, export al 70%. Stack: Google Workspace (la scelta del fondatore,

che voleva "qualcosa di diverso da Microsoft"), Slack per comunicazioni interne, Dropbox per disegni tecnici, PEC InfoCert.

Il trigger. Una proposta di acquisizione da parte di un gruppo cinese, nel 2024, è transitata via Gmail tra i due soci dell'azienda. Una mail interna delicata è poi finita "per errore" inoltrata a un broker concorrente. La trattativa è saltata e i soci sono in disputa interna sul chi ha inoltrato cosa. Senza prova crittografica del contenuto, la disputa è oggi al consulente tecnico — costo stimato 80.000 euro di parcelle legali e perdita della trattativa di acquisizione (valore: ~12 milioni).

Il rollout. I soci hanno chiesto a Lattice un setup d'emergenza in 4 settimane, focalizzato sulle comunicazioni dei vertici (15 utenti). Il resto dell'azienda continua su Google Workspace.

I numeri. Investimento fase iniziale: 55.000 euro. Beneficio: in futuri scenari M&A, le comunicazioni saranno crittograficamente attribuibili. Le dispute interne tra soci su "chi ha inoltrato cosa" diventano risolvibili in 30 secondi sul Block Explorer.

Cosa è cambiato qualitativamente. I soci hanno introdotto Lattice nelle comunicazioni interne strategiche e hanno deciso di estendere progressivamente a tutta l'azienda nel 2026-2027. Per loro, il valore principale non è la sostituzione di Google (che hanno tenuto) ma l'**isolamento di un perimetro ristretto di comunicazione critica** dove le regole sono diverse.

13.5 — Il pattern comune

Da questi quattro casi, emerge un pattern: **Lattice non sostituisce mai integralmente Microsoft/Google al primo giorno**.

Sostituisce — con un beneficio enorme e misurabile — il **sottoinsieme di comunicazioni dove la sovranità conta davvero**. Il resto può rimanere su Microsoft/Google per pragmatismo.

Questo è il modello "ibrido controllato" che abbiamo descritto nel cap. 6.5 e che resta la raccomandazione per la grande maggioranza dei clienti.

L'errore tipico delle aziende che approcciano la sovranità è il "tutto o niente": o resto totalmente su Microsoft (e sono esposto), o devo migrare totalmente (e mi spavento, e non lo faccio mai). Il modello giusto è il triage: identifica il 10-30% di comunicazioni dove la sovranità è critica e mettilo al sicuro. Per il resto, valuta nel tempo.

13.6 — ROI e tempi di payback

In sintesi, dai quattro casi:

Settore	Investimento	Risparmio annuo	Payback	Beneficio principale non monetario
Banca	380.000 €	270.000 €/anno	14 mesi	Continuità operativa in caso di sospensione fornitore
Studio legale	95.000 €	22.000 €/anno	4.5 anni	Prova crittografica indipendente
Comune	60.000 €	18.000 €/anno	3.5 anni	Conformità NIS2 dimostrabile

Manifatturiero	55.000 €	(non quantif.)	(a evento)	Risoluzione M&A future

Il payback medio è di 2-4 anni per il TCO, ma il valore principale per ogni settore è quello non monetario: **continuità, prova, conformità, riservatezza**. Sono i valori che il consiglio non vorrebbe mai vedere quantificati a posteriori — perché significherebbe che è successo qualcosa.

13.7 — Domanda per il proprio settore

A prescindere dal settore della vostra azienda, una buona domanda è: **"Quale evento, nei prossimi cinque anni, ci porterebbe a desiderare di aver avuto un'infrastruttura di comunicazione sovrana? Cosa ci costerebbe quell'evento se accadesse oggi?"**

Per ogni settore la risposta è diversa. Ma la conclusione operativa è sempre la stessa: il momento giusto per costruire l'infrastruttura è prima dell'evento, non dopo.

CAPITOLO 14 — Roadmap dell'autosovranità.

14.0 — Apertura

Abbiamo raccontato il problema (parti I), la sovranità come categoria operativa (parte II), Lattice come risposta tecnica (parte III), il quadro normativo e i casi d'uso (parte IV). Questo capitolo finale è il più pragmatico di tutti: indica i passi concreti per costruire l'autosovranità delle comunicazioni nei prossimi 18 mesi, indipendentemente da Lattice come prodotto specifico.

Anche se sceglieste un'altra strada (un'altra piattaforma sovrana, un mix di soluzioni, una soluzione interna), la sequenza di pensiero sarebbe la stessa. Quella che segue è una roadmap operativa applicabile a qualunque azienda italiana sopra i 30 dipendenti.

14.1 — Mese 0: l'inventario

Prima di decidere qualunque cosa, occorre sapere dove si è oggi. Un inventario delle comunicazioni aziendali in genere richiede 2-4 settimane di lavoro di un comitato ristretto (IT manager + responsabile compliance + un rappresentante del legale).

Domande dell'inventario:

61. **Quali fornitori cloud gestiscono nostre comunicazioni?** (Microsoft, Google, Slack, PEC, Dropbox, WhatsApp Business, altri).
62. **In quali datacenter sono fisicamente i dati?**
63. **Quante mail aziendali al giorno?** (totali e per tipologia di valore).
64. **Quante chat aziendali al giorno?**
65. **Quali tipi di comunicazioni hanno valore probatorio o strategico?**
66. **Quali contratti di fornitura ICT sono in essere, con quali clausole di terminazione, con quali penali?**
67. **Quante volte negli ultimi 24 mesi abbiamo avuto problemi con il fornitore primario?**
68. **Qual è il danno operativo stimato di una sospensione del fornitore primario per 24, 72, 168 ore?**

L'output dell'inventario è un documento di 10-20 pagine che il CdA può discutere. Senza di esso, le decisioni successive si prendono nel buio.

14.2 — Mese 1-2: la priorità strategica

Dato l'inventario, occorre identificare il 10-30% di comunicazioni che merita un trattamento sovrano. Sono tipicamente:

- Comunicazioni del consiglio.
- Trattative M&A in corso o prevedibili.
- Contenziosi attivi e potenziali.
- Brevetti e segreti industriali.

- Comunicazioni con organi di vigilanza (per banche, assicurazioni, sanità).
- Comunicazioni con clienti chiave (i top 10 per fatturato o sensibilità).
- Decisioni HR delicate (sanzioni, licenziamenti, casi disciplinari).

Per ogni categoria identificata, valutare: chi parla con chi, quanti messaggi al mese, quanto sopravvivono i dati (vita utile), qual è il costo di una compromissione.

L'output è una matrice "categoria di comunicazione × livello di criticità", che diventa input della scelta tecnologica del mese 3.

14.3 — Mese 3: la scelta tecnologica

A questo punto si confrontano le opzioni. Le principali, oggi (febbraio 2026):

Opzione 1 — Continuare con Microsoft/Google + sovereign cloud option. Costo: relativamente basso. Beneficio di sovranità: minimo (capitolo 5). Tempo di implementazione: rapido.

Opzione 2 — Costruire infrastruttura interna ad hoc. Costo: alto (250-800k a seconda della dimensione). Beneficio di sovranità: massimo, ma a rischio di realizzazione. Tempo: 12-24 mesi.

Opzione 3 — Adottare Lattice (o un equivalente sovrano europeo). Costo: medio (50-400k investimento iniziale a seconda della dimensione). Beneficio di sovranità: alto e dimostrato. Tempo: 3-6 mesi.

Opzione 4 — Ibrida: Microsoft/Google per comunicazioni leggere + Lattice per quelle critiche. Costo: medio. Beneficio: equilibrio pragmatico. Tempo: 3-6 mesi.

Per la stragrande maggioranza delle aziende italiane, l'opzione 4 è la raccomandazione: massimizza il valore sovrano dove conta, minimizza la disruption sul resto.

14.4 — Mese 3-4: l'installazione

Una volta scelta la tecnologia, l'installazione segue uno schema standard:

Settimana 1. Setup dell'infrastruttura (server fisici o cloud sovrano). Configurazione di rete. Backup. Sicurezza perimetrale.

Settimana 2. Installazione del software (Lattice o equivalente). Test interni. Configurazione delle policy aziendali.

Settimana 3. Generazione delle prime identità (founder + key admin). Setup del Key Recovery (Shamir 2-di-3 con guardiani designati). Test di recupero.

Settimana 4. Onboarding dei primi utenti pilota (10-30 persone, tipicamente il team strategico). Training. Validazione.

Per aziende che hanno scelto cloud sovrano selezionato, la settimana 1 può essere ridotta a 2-3 giorni. Per chi installa on-premise da zero, può estendersi a 2 settimane.

14.5 — Mese 5-9: l'estensione

Una volta che il pilota è stabile, l'estensione segue il pattern "ondate progressive":

Ondata 1 (mese 5). Estensione al primo reparto completo (es. legale + compliance + finanza). Tipicamente 20-50 persone aggiunte.

Ondata 2 (mese 6-7). Estensione al secondo reparto strategico (es. commerciale o R&D). Altre 30-100 persone.

Ondata 3 (mese 8-9). Estensione al resto dell'organizzazione (il "lungo coda" di reparti minori e personale operativo).

In parallelo: progressiva riduzione della licenza Microsoft 365 (da Business Premium a Plan 1), eliminazione di Slack e Dropbox per le comunicazioni interne, mantenimento di PEC solo per comunicazioni con PA italiane che la richiedono per legge.

14.6 — Mese 10-12: la stabilizzazione

L'ultimo trimestre del primo anno è dedicato alla stabilizzazione operativa:

- Audit interno completo dell'infrastruttura Lattice.
- Verifica delle policy di backup e disaster recovery.
- Esercitazione di emergenza (es. sospensione simulata del fornitore primario residuo, verifica della continuità Lattice).
- Documentazione di compliance per NIS2/DORA/GDPR.
- Eventuale audit esterno indipendente (consulenza ISO 27001 o equivalente).

Al termine del mese 12, l'azienda è in una posizione di sovranità sostanziale per la maggior parte delle sue comunicazioni critiche.

14.7 — Anno 2 e oltre: gli sviluppi naturali

Una volta che la sovranità delle comunicazioni è stata stabilita, emergono naturalmente sviluppi correlati:

Identità sovrana dell'azienda. L'azienda inizia a usare le proprie identità LNS come "carta di identità digitale aziendale" per: portali clienti, autenticazione su sistemi terzi (via SAML/OIDC), firma di documenti, accessi fisici (badge).

Archivio sovrano dei documenti. Oltre alle mail e alle chat, l'azienda sposta su Lattice (o su un sistema integrato) anche l'archivio dei documenti firmati, brevetti, contratti.

Comunicazione cross-aziendale sovrana. Con il diffondersi di Lattice (e di sistemi compatibili), le aziende iniziano a comunicare tra loro sovranamente. Questo è il punto di svolta: la sovranità non è più solo "interna" ma diventa un'infrastruttura B2B.

EUDI Wallet integration. L'arrivo dell'European Digital Identity Wallet entro il 2027 si integra naturalmente con Lattice: i cittadini possono identificarsi verso le aziende via EUDI, le aziende rispondono via Lattice.

14.8 — Il senso ultimo

Il senso ultimo di questa roadmap non è "passare a Lattice". È **riprendere in mano il controllo della propria infrastruttura di comunicazione**. Lattice è una delle risposte operative possibili al 2026 — quella più completa, secondo gli autori. Ma il problema, e la necessità di rispondervi, restano indipendentemente dal prodotto scelto.

Un consiglio di amministrazione che, alla fine di un anno fiscale, può dire "abbiamo riportato sotto controllo le nostre comunicazioni

più importanti" ha fatto una cosa che pochissimi CdA italiani potranno dire nei prossimi 24 mesi. È una differenza che, in caso di crisi, si misura in milioni di euro non persi, in cause non perdute, in reputazioni protette.

14.9 — Domanda finale

Portate al prossimo consiglio questa domanda, l'unica importante: **"Quanto tempo possiamo ancora permetterci di affidare le nostre comunicazioni più importanti a fornitori che possono sospenderle senza preavviso, leggerle senza autorizzazione e modificarne il valore probatorio retroattivamente?"**

Se la risposta è "non molto", il momento di partire è adesso. La roadmap che avete appena letto è di 12 mesi. Inizia oggi.

Buon viaggio.

— *Gli autori, Milano, febbraio 2026*

APPENDICI

APPENDICE A — Glossario tecnico

AEAD (Authenticated Encryption with Associated Data) — Modalità di cifratura che combina riservatezza e integrità in una singola operazione. Es: AES-256-GCM, ChaCha20-Poly1305.

Anchor / Anchoring on-chain — Operazione di registrare uno hash su una blockchain pubblica (in Lattice: Bitcoin via OpenTimestamps) come prova di esistenza temporale.

Argon2id — Algoritmo di derivazione di chiave da password, vincitore della Password Hashing Competition (2015). Resistente sia a attacchi GPU che a side-channel attack.

Audit log hash-chained — Registro di operazioni in cui ogni voce contiene lo hash della precedente, in modo che la modifica di una voce invalidi tutta la catena successiva.

BLS (Boneh-Lynn-Shacham) — Schema di firma su curve ellittiche che supporta l'aggregazione di firme. Usato in protocolli di consenso come Ethereum 2.0.

BSL 1.1 (Business Source License) — Licenza software che consente uso non commerciale, ispezione, modifica, ma riserva l'uso commerciale al licenziante. Conversione automatica a Apache 2.0 dopo 4 anni.

Chaum-Pedersen Σ-protocol — Famiglia di protocolli interattivi zero-knowledge per provare la conoscenza di un logaritmo discreto. In Lattice usato per ZK-RLN.

CLOUD Act — Legge federale statunitense del 2018 che autorizza l'autorità giudiziaria americana a ordinare a operatori statunitensi la consegna di dati ovunque archiviati.

Double Ratchet — Protocollo di key derivation per messaggistica E2E, introdotto da Signal nel 2014. Garantisce forward secrecy e post-compromise security.

DORA (Digital Operational Resilience Act) — Regolamento UE 2022/2554. In vigore dal gennaio 2025. Definisce requisiti di resilienza ICT per operatori finanziari.

E2E (End-to-End) — Modello di cifratura dove solo mittente e destinatario finali possono leggere il contenuto; nessun intermediario, incluso il server, ha accesso.

eIDAS (electronic IDentification, Authentication and trust Services) — Regolamento UE 910/2014 (e successive modifiche eIDAS 2.0 del 2024) sui servizi di identità e firma elettronica.

Envelope encryption — Tecnica per cifrare i dati con una "data encryption key" che a sua volta è cifrata da una "key encryption key" più protetta.

Fingerprint (di una chiave pubblica) — Hash compatto (tipicamente 8-16 byte) di una chiave pubblica, usato per riferimento visivo o verifica.

Forward Secrecy — Proprietà per cui la compromissione di una chiave attuale non consente di decifrare comunicazioni passate.

FIPS (Federal Information Processing Standards) — Standard pubblicati dal NIST. FIPS 203 = ML-KEM, FIPS 204 = ML-DSA, FIPS 205 = SLH-DSA.

Groth16 — Sistema di zero-knowledge proof non-interattivo basato su curve a pairing. Produce proof molto piccole (~200 byte) ma richiede setup di parametri pubblici.

Hash-chain — Struttura dati lineare dove ogni elemento include lo hash dell'elemento precedente. Rende impossibili modifiche retroattive senza essere rilevate.

HSM (Hardware Security Module) — Dispositivo hardware dedicato alla custodia di chiavi crittografiche, con protezioni anti-tamper.

JWT (JSON Web Token) — Standard per token di autenticazione firmati, con header, payload e signature in base64.

KDF (Key Derivation Function) — Funzione che deriva una chiave crittografica da un materiale segreto (password, master key, shared secret).

LNS (Lattice Name System) — Sistema di naming gerarchico usato in Lattice per identità (es: `mario.rossi@dipartimento.tenant.lns`).

Loopix — Protocollo accademico (USENIX 2017) per mixnet anonimi moderni con delay-based mixing.

Master Key — Chiave crittografica di alto livello da cui derivano (via KDF) altre chiavi operative.

Merkle tree — Struttura dati ad albero binario dove ogni nodo interno è lo hash dei figli. Permette prove efficienti di inclusione.

ML-DSA-65 — Module-Lattice Digital Signature Algorithm, livello 5 (~256-bit security). Standard NIST FIPS 204. Era "Dilithium3".

ML-KEM-768 — Module-Lattice Key Encapsulation Mechanism, livello 3 (~192-bit security). Standard NIST FIPS 203. Era "Kyber-768".

MLWE (Module Learning With Errors) — Problema computazionale alla base di ML-DSA e ML-KEM. Resistente al quantum computing (per quanto si sa oggi).

NIS2 (Network and Information Security 2) — Direttiva UE 2022/2555. Recepita in Italia con DLgs 138/2024.

Nullifier — Valore deterministico ma unilineare derivato da un segreto, usato in ZK-RLN per identificare l'unicità di un'azione senza identificare l'autore.

OpenTimestamps (OTS) — Protocollo open source per anchorare hash su blockchain Bitcoin in modo efficiente batch.

PBFT (Practical Byzantine Fault Tolerance) — Algoritmo di consenso distribuito (Castro & Liskov, 1999) tollerante a guasti bizantini.

PEC (Posta Elettronica Certificata) — Sistema di posta elettronica con valore legale italiano, regolato da DPR 68/2005.

Perfect Forward Secrecy (PFS) — Vedi Forward Secrecy.

Post-Compromise Security (PCS) — Proprietà per cui, dopo la compromissione di una chiave, le comunicazioni future tornano sicure grazie al re-keying.

PQC (Post-Quantum Cryptography) — Crittografia resistente a computer quantistici. Standardizzata da NIST tramite il programma PQCSP iniziato nel 2016.

PQXDH (Post-Quantum Extended Diffie-Hellman) — Estensione post-quantistica di X3DH (handshake di Signal), introdotta nel 2023.

PyO3 — Framework Rust per creare binding Python di codice Rust. Usato in Lattice per il bridge `lattice-py`.

QBFT (Quorum Byzantine Fault Tolerance) — Variante di PBFT ottimizzata per scenari enterprise con piccolo numero fisso di validatori.

RLN (Rate-Limiting Nullifier) — Schema crittografico per limitare il rate di azioni anonime usando zero-knowledge proofs.

RTO/RPO (Recovery Time Objective / Recovery Point Objective) — Metriche di disaster recovery: tempo per ripristinare il servizio / dati massimi persi.

RSA-2048 — Algoritmo di firma e cifratura a chiave pubblica basato sulla difficoltà di fattorizzare grandi numeri. Vulnerabile a Shor.

Sealed Sender — Tecnica di Signal per nascondere l'identità del mittente al server, mantenendola visibile solo al destinatario.

SHA-3 / SHA3-256 / SHA3-512 — Famiglia di funzioni hash basate su Keccak, standardizzate da NIST FIPS 202 (2015). Diversa struttura interna da SHA-2.

Shamir Secret Sharing — Algoritmo per dividere un segreto in N parti tali che K (con $K \leq N$) parti siano sufficienti a ricostruirlo, ma K-1 non rivelino nulla.

Shor's algorithm — Algoritmo quantistico (Shor, 1994) che risolve fattorizzazione e logaritmo discreto in tempo polinomiale.

SLH-DSA (Stateless Hash-Based Digital Signature Algorithm) — Standard FIPS 205, basato solo su hash function. Era "SPHINCS+".

SPID (Sistema Pubblico di Identità Digitale) — Sistema italiano di identità digitale, ~38 milioni di utenti registrati.

TOTP (Time-based One-Time Password) — Standard RFC 6238 per password monouso basate sul tempo. Usato in Lattice per 2FA.

WASM (WebAssembly) — Formato binario per eseguire codice nel browser ad alte prestazioni. Lattice usa WASM per le operazioni client-side ML-DSA-65.

X3DH / X25519 — Protocollo di handshake di Signal (X3DH) basato su scambio Diffie-Hellman su curva Curve25519 (X25519).

Zero-Knowledge Proof (ZKP) — Procedura crittografica per dimostrare la conoscenza di un segreto senza rivelarlo.

APPENDICE B — Come verificare indipendentemente una ricevuta Certify

Una delle proprietà che distinguono Certify dalla PEC tradizionale è che **la verifica della validità di una ricevuta non richiede alcun software proprietario di Lattice**. Chiunque, in qualsiasi momento — anche tra trent'anni, anche se Lattice non esistesse più — può convincersi della validità di una ricevuta seguendo cinque passi standard.

I cinque passi sono i seguenti.

Passo 1: ricostruire il payload canonico. A partire dalle informazioni presenti nel PDF della ricevuta (mail ID, data di seal, mittente, destinatario, hash del documento), si ricostruisce la

stringa canonica firmata dal destinatario. Le regole di costruzione sono pubbliche e descritte nell'appendice C.

Passo 2: calcolare lo hash SHA3-512 del payload canonico. SHA3-512 è uno standard NIST FIPS 202, pubblicato nel 2015 e implementato in ogni libreria crittografica moderna. Il valore calcolato deve coincidere con quello stampato nel PDF della ricevuta (campo "Preimage hash").

Passo 3: recuperare la chiave pubblica del firmatario. La chiave pubblica del destinatario al momento della firma (1.952 byte, formato ML-DSA-65) può essere recuperata da: (a) l'archivio del deployment Lattice di emissione, se ancora disponibile; (b) l'archivio storico di ricerca AgID, se richiesto; (c) il fingerprint stampato nel PDF, che permette di disambiguare la chiave tra più candidate.

Passo 4: verificare la firma ML-DSA-65 standard NIST FIPS 204. Usando una qualsiasi implementazione di riferimento dell'algoritmo (la libreria di riferimento del NIST è PQClean, disponibile in C, Rust, Python, JavaScript), si verifica che la firma sia stata effettivamente generata con la chiave privata corrispondente alla pubblica recuperata, applicata al payload canonico ricostruito al passo 1. Se la verifica matematica passa, **la ricevuta è autentica**.

Passo 5 (opzionale ma raccomandato): verificare l'anchor OpenTimestamps su Bitcoin. Il PDF della ricevuta contiene un riferimento al blocco QBFT e al successivo anchor OTS sulla blockchain Bitcoin (avviene ogni 6 ore). Questo passo aggiunge una garanzia "perpetua" indipendente da qualsiasi sistema italiano o europeo: chiunque, con qualsiasi nodo Bitcoin del mondo, può verificare che, in un certo momento di un certo giorno, esisteva un

blocco QBFT con quel particolare hash di stato. È la prova di esistenza temporale di ultima istanza.

I cinque passi possono essere eseguiti da:

- Un consulente tecnico nominato da un giudice in giudizio civile.
- Un perito grafologo informatico in giudizio penale.
- Un auditor interno dell'organizzazione titolare.
- Un singolo cittadino con conoscenze tecniche di base.

Il punto chiave è che **nessuno di questi attori deve fidarsi di Lattice**, né del fornitore Lattice, né del deployment originario. Si fida solo della matematica e degli standard pubblici (NIST FIPS 202, FIPS 204, OpenTimestamps, Bitcoin protocol).

Per informazioni operative su come eseguire la verifica e link alle librerie di riferimento, contattare l'assistenza Lattice o consultare la documentazione tecnica pubblica.

APPENDICE C — Specifica del formato della ricevuta PEC court-grade

La ricevuta PDF generata da `GET /api/certify/{mail_id}/receipt.pdf` ha la struttura seguente (formato A4, orientamento verticale, font Helvetica e Helvetica-Bold).

Header (margine superiore)

- Titolo "LATTICE NETWORK" in Helvetica-Bold 18pt, colore RGB (10, 15, 30).

- Sottotitolo "RICEVUTA DI CONSEGNA · PROVA LEGALE OPPONIBILE" in Helvetica 9pt, colore RGB oro (212, 175, 55).
- Timestamp UTC dell'emissione del PDF in alto a destra.
- Linea di separazione di 1.2pt in colore oro.

Sezione 1: identificazione della comunicazione

Coppie etichetta/valore:

- `MAIL ID`: identificatore univoco
- `MITTENTE`: LNS completo
- `DESTINATARIO`: LNS completo
- `DATA INVIO`: ISO 8601 UTC
- `CLASSIFICAZIONE`: INTERNAL / CONFIDENTIAL / SECRET
- `OGGETTO`: subject originale (eventualmente redacted secondo policy)
- `HASH DOCUMENTO (SHA3-512)`: prime 96 caratteri esadecimali

Sezione 2: ricevuta di apertura firmata digitalmente

- `FIRMATA DA (LNS DESTINATARIO)`: LNS del firmatario
- `DATA FIRMA`: ISO 8601 UTC
- `ALGORITMO`: "ML-DSA-65 (NIST FIPS 204 · post-quantum)"
- `PREIMAGE HASH (SHA3-512)`: 128 caratteri esadecimali
- `FIRMA DIGITALE (ML-DSA-65, 3309 byte)`: prime 120 caratteri della firma + ellipsis

Sezione 3: notarizzazione blockchain

- `TRANSACTION ID`: tx-XXXXXXXXXXXX

- BLOCK INDEX: #N
- CONSENSO: "QBFT · 4 validatori · 3/4 firme ML-DSA-65"
- CATENA: "lattice-sovereign-it-prod"

Sezione 4: istruzioni di verifica indipendente

Cinque punti di guida testuale per la verifica:

69. Ricostruire il payload canonico.
70. Recuperare la chiave pubblica del destinatario.
71. Verificare la firma ML-DSA-65.
72. Verificare il blocco QBFT.
73. (Opzionale) Verificare l'anchor OpenTimestamps su Bitcoin.

Footer (margine inferiore)

- Disclaimer legale in 4-5 righe corsivo 7.5pt, colore grigio scuro.
- Riga in oro, Helvetica-Bold 7pt: "LATTICE NETWORK · cybersicurezza sovrana · Contatti".

Caratteristiche tecniche del PDF

- Conforme a PDF/A-2b per archiviazione di lungo termine.
- Tutti i font incorporati (subsetted).
- Metadati XMP con dichiarazione del software, della versione, dell'algoritmo crittografico.
- Dimensione tipica: 4-8 KB per ricevuta semplice, 15-30 KB con allegati.

- SHA-256 del PDF stesso pubblicato in `/api/certify/{mail_id}/receipt.pdf.sha256`.

APPENDICE D — Bibliografia

Standard ufficiali NIST/IETF/ISO

- NIST FIPS 203 — Module-Lattice-Based Key-Encapsulation Mechanism Standard (2024).
- NIST FIPS 204 — Module-Lattice-Based Digital Signature Standard (2024).
- NIST FIPS 205 — Stateless Hash-Based Digital Signature Standard (2024).
- NIST FIPS 202 — SHA-3 Standard (2015).
- NIST SP 800-208 — Recommendation for Stateful Hash-Based Signature Schemes (2020).
- RFC 6238 — TOTP: Time-Based One-Time Password Algorithm (2011).
- RFC 8032 — Edwards-Curve Digital Signature Algorithm (EdDSA) (2017).
- ISO/IEC 27001:2022 — Information security, cybersecurity and privacy protection.
- ISO/IEC 19790:2025 — Cryptographic modules (in pubblicazione).

Paper accademici fondamentali

- Castryck, W., Decru, T. (2023) — An efficient key recovery attack on SIDH. EUROCRYPT.

- Castro, M., Liskov, B. (1999) — Practical Byzantine Fault Tolerance. OSDI.
- Gidney, C., Ekerå, M. (2021) — How to factor 2048-bit RSA integers in 8 hours using 20 million noisy qubits. Quantum.
- Piotrowska, A., et al. (2017) — The Loopix Anonymity System. USENIX Security.
- Shor, P. (1994) — Algorithms for quantum computation: discrete logarithms and factoring. FOCS.
- Signal Foundation (2023) — PQXDH: Post-Quantum X3DH.

Normativa europea e italiana

- Regolamento UE 2016/679 (GDPR).
- Direttiva UE 2022/2555 (NIS2).
- Regolamento UE 2022/2554 (DORA).
- Regolamento UE 910/2014 (eIDAS) e successive modifiche 2024/1183 (eIDAS 2.0).
- DLgs 138/2024 (recepimento NIS2 in Italia).
- DLgs 82/2005 (Codice dell'Amministrazione Digitale, CAD).
- DPR 68/2005 (PEC).
- Provvedimenti del Garante Privacy 2022-2025 sull'art. 32 GDPR.

Risorse pratiche

- PQClean: https://github.com/PQClean/PQClean
- libsodium: https://libsodium.gitbook.io/
- OpenTimestamps: https://opentimestamps.org/
- arkworks (Rust ZK toolkit): https://github.com/arkworks-rs

- Signal Protocol documentation: https://signal.org/docs/

APPENDICE E — Il Manifesto Lattice

12 principi per la sovranità digitale italiana.

74. **La crittografia è un diritto fondamentale.** Tutela il diritto costituzionale alla riservatezza (art. 15) e alla segretezza della corrispondenza.
75. **La sovranità si misura in chi possiede le chiavi.** Non in chi possiede il logo, il dominio, il datacenter. Le chiavi.
76. **Il codice deve essere ispezionabile sempre.** Senza accesso al sorgente, "sicurezza" è solo un atto di fede.
77. **I dati devono restare dove nasce la loro responsabilità.** I dati italiani in Italia. I dati di un'organizzazione, sotto il suo controllo.
78. **Le prove crittografiche devono essere verificabili per trent'anni e oltre.** Non per "il tempo del contratto col vendor".
79. **Nessuno standard è inviolabile: usa solo standard NIST e ISO.** L'innovazione fa progressi, ma gli standard sono il pavimento minimo.
80. **Il vendor lock-in è incompatibile con la sovranità.** Un sistema sovrano deve permettere di andarsene in qualsiasi momento, con tutti i propri dati.
81. **I metadati sono dati, e meritano la stessa protezione.** Chi sa "chi parla con chi" sa molto.
82. **Nessuna terza parte deve poter leggere ciò che non ti appartiene.** Né operatore, né provider, né autorità — senza un mandato giudiziario specifico e proporzionato.

83. **La compliance non è uno scopo — è il pavimento.** È il minimo, non il massimo. La sicurezza vera supera ampiamente i requisiti di compliance.

84. **La velocità di adozione è una vulnerabilità.** Non corriamo per essere primi. Corriamo per essere giusti.

85. **L'autosovranità italiana è la sovranità di domani.** Costruiamola, ingegnere per ingegnere, organizzazione per organizzazione, città per città.

— Lattice Network

IL MANIFESTO LATTICE

12 principi per la sovranità digitale italiana

1. La crittografia è un diritto fondamentale.
2. La sovranità si misura in chi possiede le chiavi.
3. Il codice deve essere ispezionabile sempre.
4. I dati restano dove nasce la loro responsabilità.
5. Le prove crittografiche devono essere valide 30+ anni.
6. Nessuno standard è inviolabile: usa NIST e ISO.
7. Il vendor lock-in è incompatibile con la sovranità.
8. I metadati sono dati: meritano la stessa protezione.
9. Nessuna terza parte legga ciò che non le appartiene.
10. La compliance è il pavimento, non il soffitto.
11. La velocità di adozione è una vulnerabilità.
12. L'autosovranità italiana è la sovranità di domani.

LATTICE NETWORK

LATTICE NETWORK

Corporate Communication Control Layer · post-quantum · self-hosted

Per richiedere un pilot, contattare:

lattice@network.it

Codice promo "BOOK-2026": 30 giorni di pilot gratis.